

SGSI ANTHROPIC

ISO 27001:2022

CNO V — Seguridad Informática

Universidad Politécnica de San Luis Potosí

Mtro. Servando López Contreras

EQUIPO 5

181700 - Castillo Gómez Edwin Admael

182033 - Castillo Olvera Carlos René

182217 - Hernández Fernández Diego Osvaldo

174702 - Tristán Rivera Magdalena Yesenia

ANTHROPIC

CONTENIDO

01	ALCANCE Descripción general, estructura organizacional, modelo de negocio, productos, infraestructura y métricas del SGSI
02	REFERENCIAS NORMATIVAS Marco normativo ISO 27000, regulaciones internacionales y estándares de cumplimiento aplicables
03	TÉRMINOS Y DEFINICIONES Glosario de 22 términos aplicados al contexto de Anthropic, basado en ISO/IEC 27000:2018
04	CONTEXTO DE LA ORGANIZACIÓN Activos internos, externos y políticas funcionales del SGSI de Anthropic
05	LIDERAZGO Política de Seguridad de la Información (PSI) con 20 políticas y matrices RACI
06	PLANIFICACIÓN Matriz de riesgo, evaluación y tratamiento de riesgos por activo
07	SOPORTE Competencia, concienciación y comunicación en el SGSI
08	OPERACIÓN Plan de tratamiento de riesgos: Sistema de Correo Corporativo
09	EVALUACIÓN DEL DESEMPEÑO Checklist de supervisión de las 20 políticas del SGSI
10	MEJORA No conformidad, acción correctiva y caso de mejora

Sección 1 - ALCANCE

Descripción general, estructura organizacional, modelo de negocio, productos, infraestructura y métricas del SGSI

ANTHROPIC

Ficha de Identificación del SGSI

Organización	Anthropic, PBC
Tipo de entidad	Public Benefit Corporation (PBC)
Sede principal	San Francisco, California, EE. UU.
Versión del SGSI	1.0
Norma de referencia	ISO/IEC 27001:2022
Clasificación	Confidencial — uso interno

1. Declaración Formal del Alcance

El presente documento define el alcance del Sistema de Gestión de Seguridad de la Información (SGSI) de Anthropic, PBC, conforme a los requisitos de la norma ISO/IEC 27001:2022, Cláusula 1.

El SGSI aplica a todos los procesos, sistemas, personas, activos de información e infraestructura tecnológica involucrados en el diseño, desarrollo, operación, mantenimiento y entrega segura de los modelos de lenguaje de gran escala (LLM) de la familia Claude, así como de las plataformas y servicios asociados que Anthropic ofrece a usuarios finales, desarrolladores y clientes enterprise.

Declaración de alcance: El SGSI de Anthropic cubre el ciclo de vida completo de los modelos Claude — desde el entrenamiento hasta la entrega al usuario final — incluyendo la infraestructura multi-cloud (GCP + AWS), los sistemas corporativos de soporte y los procesos de seguridad operativa, en todas las ubicaciones y entornos bajo gestión directa de Anthropic.

2. Misión, Visión y Propósito Corporativo

La misión y visión de Anthropic determinan el contexto estratégico en que opera el SGSI y justifican el nivel de protección requerido sobre los activos de información críticos, en especial los pesos de los modelos y los datos de los usuarios.

MISIÓN

Construir sistemas de inteligencia artificial en los que las personas puedan confiar, generando investigación sobre las oportunidades y riesgos de la IA para beneficio de la humanidad a largo plazo.

VISIÓN

Ser el referente mundial en IA segura, guiar responsablemente la transición tecnológica e inspirar una industria donde la seguridad y la ética sean el estándar competitivo universal.

Tres Pilares del Propósito PBC

01 Sistemas más Seguros IA confiable, interpretable y dirigible que pueda ser auditada y corregida	02 Seguridad como Ciencia Investigación sistemática y reproducible sobre riesgos de IA, publicada abiertamente	03 Interdisciplinariedad Equipos de investigadores, ingenieros y expertos en política pública y ética
--	--	---

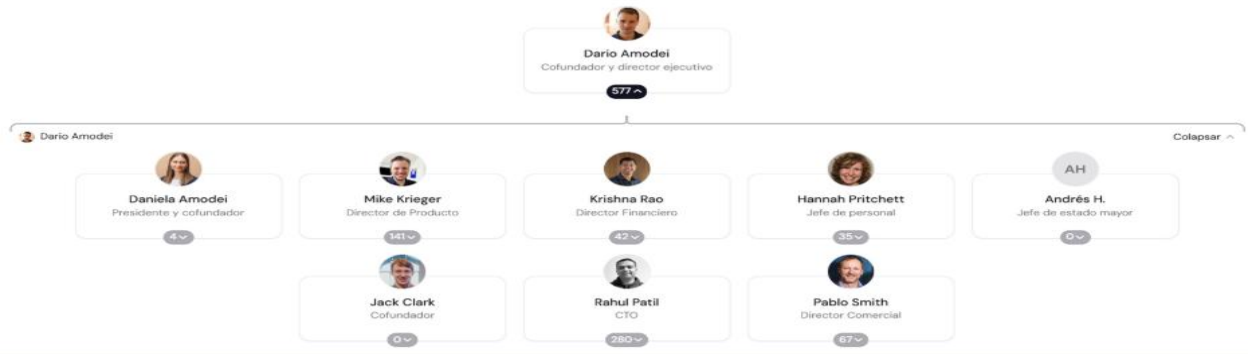
Relevancia para el SGSI: El mandato de Anthropic como PBC exige que la seguridad de la información no sea solo un control técnico, sino un compromiso ético y legal. Los tres pilares fundamentan la política de seguridad del SGSI y su alineación con el bienestar de la humanidad.

3. Estructura Organizacional

Anthropic opera bajo un modelo de liderazgo distribuido. El CEO Dario Amodei encabeza la organización con 577 reportes directos e indirectos, apoyado por una dirección ejecutiva multidisciplinaria. La estructura organizacional determina las responsabilidades sobre los activos de información en alcance del SGSI.

Nombre	Cargo	Equipo a cargo
Dario Amodei	Cofundador y Director Ejecutivo (CEO)	577
Daniela Amodei	Presidenta y Cofundadora	4
Rahul Patil	Director de Tecnología (CTO)	280
Mike Krieger	Director de Producto	141
Pablo Smith	Director Comercial	67
Krishna Rao	Director Financiero (CFO)	42
Hannah Pritchett	Jefe de Personal	35
Jack Clark	Cofundador	—
Andrés H.	Jefe de Estado Mayor	—

El CTO (Rahul Patil, 280 personas) es el responsable técnico principal del SGSI. El CFO (Krishna Rao) supervisa los activos financieros asociados. El Director Comercial (Pablo Smith) gestiona las relaciones con clientes enterprise y sus requisitos contractuales de seguridad.



4. Ubicaciones Físicas y Lógicas

Ubicaciones físicas

- Sede principal: San Francisco, California, EE. UU. (oficinas corporativas, empleados y sistemas de gestión)
- Regiones cloud GCP: us-central1, us-east1 y regiones adicionales para failover y cumplimiento de residencia de datos
- Regiones cloud AWS: us-east-1, us-west-2 y regiones adicionales según requisitos de clientes enterprise

Entornos lógicos en alcance

- Entorno de producción: Infraestructura de inferencia en tiempo real (GCP TPUs + AWS Inferentia2)
- Entorno de entrenamiento: Clústeres de cómputo para entrenamiento y fine-tuning de modelos (TPUs v4/v5 + GPUs A100/H100)
- Entorno de evaluación / Red-Teaming: Sistemas de pruebas adversariales y análisis de seguridad
- Entorno corporativo: Sistemas internos de gestión (GitHub, Slack, Okta, SIEM, herramientas de productividad)

No se cuenta con instalaciones físicas propias de cómputo. Toda la infraestructura de procesamiento opera en entornos cloud bajo los marcos de seguridad compartida de GCP y AWS, con responsabilidades claramente delimitadas mediante los acuerdos de proveedor.

5. Coherencia con el Contexto de la Organización

El alcance definido en esta cláusula es coherente con los factores internos y externos identificados en la Cláusula 4 (Contexto de la Organización) del SGSI de Anthropic. Los elementos clave que fundamentan esta coherencia son:

- Misión PBC: La obligación legal de considerar el impacto social positivo justifica un alcance amplio que incluye todos los sistemas que procesan datos de usuarios o que podrían causar daño si son comprometidos.
- Modelo B2B2C: La existencia de múltiples segmentos de clientes (consumidores, desarrolladores, enterprise) implica distintos niveles de criticidad y requisitos de seguridad que el SGSI debe cubrir de forma unificada.
- SOC 2 Tipo II: La certificación vigente de controles de seguridad por auditor externo es evidencia de madurez y debe mantenerse coherente con el SGSI ISO 27001 en proceso de certificación.

El alcance del SGSI de Anthropic cubre algunos de los sistemas y procesos que sustentan el desarrollo y operación de Claude, siendo este el activo estratégico central de la organización. La declaración de alcance es revisada anualmente o ante cambios significativos en la estructura organizacional, el portafolio de productos o el entorno regulatorio. En general, el presente documento se basará en el departamento dirigido por el CTO.

Sección 2 - REFERENCIAS NORMATIVAS

Marco normativo ISO 27000, regulaciones internacionales y
estándares de cumplimiento aplicables

ANTHROPIC

Normas ISO/IEC de la Familia 27000

Norma	Descripción y Aplicabilidad
ISO/IEC 27000:2018	Visión general y vocabulario. Define 81 términos utilizados en toda la familia ISO 27000. Base conceptual indispensable para la Cláusula 3 (Términos y Definiciones) del presente SGSI.
ISO 27001:2022	Norma principal de certificación SGSI. 10 cláusulas + Anexo A con 93 controles organizacionales, de personas, físicos y tecnológicos. Anthropic cuenta con certificación vigente.
ISO 27002:2022	Código de buenas prácticas. Guía de implementación de los 93 controles del Anexo A. La más referenciada en el diseño de controles de Anthropic.
ISO 27005:2022	Gestión de riesgos de seguridad de la información. Metodología para identificar, analizar, evaluar y tratar riesgos del SGSI.
ISO 27017:2015	Controles de seguridad en servicios en la nube. Altamente relevante: toda la infraestructura de Anthropic opera en GCP y AWS.
ISO 27018:2019	Protección de PII en la nube pública. Aplica al tratamiento de datos personales de usuarios de Claude.ai y clientes de la API.
ISO 27032:2023	Directrices para la ciberseguridad. Cubre jailbreaking, inyección de prompt, exfiltración de datos y ataques a la cadena de suministro de IA.
ISO 27035:2023	Gestión de incidentes de seguridad. Proceso de detección, clasificación, contención, erradicación y recuperación ante incidentes.
ISO 27701:2019	Extensión de privacidad para SGSI. Especifica requisitos para la gestión de información de privacidad (PIMS). Complementa ISO 27001 en el tratamiento de datos personales de usuarios de Claude.ai y la API.
ISO 27031:2011	Continuidad de negocio para TIC. Directrices para preparar sistemas de información para la continuidad del negocio. Aplica a la resiliencia operacional de los servicios de Claude.
ISO/IEC 42001:2023 *	Sistema de Gestión de IA (AIMS). Primer estándar internacional de gobernanza de IA. Anthropic cuenta con certificación vigente. Cubre ética, transparencia, sesgo y ciclo de vida de modelos como Claude. (*) Pertenece a la familia ISO/IEC 42000, no a la 27000, pero es aplicable directamente al contexto de IA de Anthropic.

Sección 3 - TÉRMINOS Y DEFINICIONES

Glosario de 22 términos aplicados al contexto de Anthropic, basado en
ISO/IEC 27000:2018

ANTHROPIC

Glosario SGSI — Términos Clave

CONCEPTOS BASE	
SGSI — Marco de políticas, procesos y sistemas para gestionar riesgos de información.	Activo de información — Datos, sistemas o elementos con valor: pesos de modelos, conversaciones, claves API, código fuente.
Alta dirección — Dario Amodei (CEO), Daniela Amodei (Presidenta) y Board of Directors.	Política — Intenciones y dirección formalmente expresadas por la alta dirección. En Anthropic: política de seguridad, uso aceptable y privacidad que rige el desarrollo y operación de Claude.
Datos personales — Cualquier información sobre una persona física identificada o identificable. En Anthropic: conversaciones, correos, identificadores de API y metadatos de sesiones de usuarios.	Responsable del tratamiento — Persona u organización que determina los fines y medios del tratamiento de datos personales. Anthropic actúa como responsable del tratamiento de datos de sus usuarios directos.
PROPIEDADES DE SEGURIDAD	
Confidencialidad — Garantiza que la información no sea revelada a entidades no autorizadas.	Integridad — Salvaguarda exactitud y completitud de activos: pesos del modelo, logs, respuestas.
Disponibilidad — API accesible ≥99.9% SLA, respaldada por arquitecturas de alta disponibilidad.	No repudio — Capacidad de demostrar la ocurrencia de un evento o acción. En Anthropic: registros de auditoría firmados que acreditan el uso de la API y accesos a sistemas críticos.
Privacidad — Derecho de las personas a controlar la recolección, uso y divulgación de su información. En Anthropic: principio rector del diseño de Claude y base de la política de privacidad del servicio.	Consentimiento — Manifestación de voluntad libre, específica e informada del interesado para el tratamiento de sus datos. En Anthropic: aceptación explícita de los términos de uso y política de privacidad.
RIESGOS Y CONTROLES	
Amenaza — Jailbreaking, prompt injection, exfiltración de datos, uso malicioso de API.	Vulnerabilidad — Fallas en filtros CAI, debilidades en validación de API, configuraciones cloud.
Riesgo — Efecto de la incertidumbre: jailbreaking, extracción de datos, no disponibilidad.	Tratamiento del riesgo — Proceso de selección e implementación de medidas para modificar el riesgo. En Anthropic: mitigación técnica, red-teaming, monitoreo continuo y planes de respuesta a incidentes.
MECANISMOS	
Autenticación — Verificación de identidad: MFA para empleados, claves API firmadas para clientes.	Autorización — Concesión de derechos de acceso bajo principio de mínimo privilegio.
Control de acceso — IAM, claves API con scopes, MFA. Acceso restringido a activos.	Cifrado — TLS 1.3 en tránsito, AES-256 en reposo en todas las comunicaciones.
GESTIÓN	
Incidente — Eventos no deseados: jailbreaks exitosos, vulneraciones de cuentas.	Brecha — Divulgación no autorizada: exposición de conversaciones, extracción de pesos.
Parte interesada — Usuarios, empresas, reguladores, investigadores, inversores, sociedad.	Evaluación de riesgo — Identificación, análisis y valoración. Instrumento principal para el tratamiento de riesgos.

Sección 4 - CONTEXTO DE LA ORGANIZACIÓN

Activos internos, externos y políticas funcionales del SGSI de Anthropic

ANTHROPIC

Activos Externos

Sistemas, plataformas y servicios de terceros sobre los que Anthropic depende, pero no controla directamente. Su seguridad es gestionada mediante acuerdos contractuales, auditorías y controles de acceso federados.

#	Activo	Descripción
1	Amazon S3 (almacenamiento de modelos)	Almacena los artefactos, pesos y checkpoints de los modelos Claude en producción. Procesa transferencias de datos entre entrenamiento e inferencia vía Amazon Bedrock.
2	Google Cloud Storage (GCS)	Almacena datasets y artefactos de modelos disponibles vía Vertex AI. Transmite datos entre pipelines de entrenamiento y los endpoints de inferencia en GCP.
3	Amazon Bedrock (inferencia en la nube)	Procesa las solicitudes de inferencia de Claude en producción. Transmite prompts de usuarios y respuestas del modelo entre clientes y los clusters Trainium.
4	Cloudflare AI Gateway	Transmite y enruta el tráfico de la API de Anthropic. Procesa metadatos de solicitudes para control de latencia, rate limiting y detección de amenazas perimetrales.
5	API pública de Claude (api.anthropic.com)	Transmite prompts y respuestas entre desarrolladores/empresas y los modelos Claude. Procesa tokens de autenticación, parámetros de solicitud y contenido generado.
6	Snowflake (datos empresariales de clientes)	Almacena y procesa datos empresariales de clientes del Claude Marketplace. Transmite consultas estructuradas entre los entornos de datos de clientes y los modelos Claude.
7	Google Cloud Vertex AI (endpoints)	Procesa solicitudes de inferencia y transmite respuestas de Claude a clientes de GCP. Almacena logs de uso y métricas de rendimiento de los modelos.
8	DNS y CDN externos (Cloudflare/Fastly)	Transmiten el tráfico web y de API hacia claude.ai y api.anthropic.com. Almacenan en caché contenido estático y distribuyen tráfico globalmente para reducir latencia.
9	Servicios de inteligencia de amenazas	Transmiten feeds de IOCs, firmas de malware y datos de amenazas activas a los sistemas SIEM de Anthropic. Procesan alertas de seguridad para el equipo de respuesta.
10	Sistema de facturación y metering externo	Procesa y almacena datos de consumo de tokens, uso de API y transacciones de suscripción de clientes. Transmite registros de uso entre la API y la plataforma de cobro.
11	GitHub (repositorios públicos de SDKs)	Almacena y transmite el código fuente público de los SDKs de Anthropic, librerías MCP y herramientas de integración. Procesa commits, pull requests y pipelines CI/CD.
12	Datadog (observabilidad y logs externos)	Recibe, almacena y procesa logs de rendimiento, trazas distribuidas y métricas de la API de Anthropic en tiempo real. Transmite alertas al equipo de operaciones.
13	Vanta (evidencias de cumplimiento)	Recopila, almacena y transmite evidencias de controles de seguridad para auditorías SOC 2 Tipo II e ISO 27001. Procesa datos de configuración de sistemas y accesos.
14	PagerDuty (alertas de incidentes)	Recibe y transmite alertas críticas de disponibilidad e infraestructura. Procesa datos de guardias, escalaciones y registros de incidentes del equipo de operaciones.
15	Okta (directorio de identidad federada)	Almacena y procesa datos de identidad de empleados (perfiles, roles, grupos). Transmite tokens de autenticación SSO entre sistemas SaaS corporativos y el IdP central.
16	Zoom / plataforma de videoconferencia	Transmite comunicaciones de audio, video y chat entre empleados, clientes y socios. Almacena grabaciones y transcripciones de reuniones internas y externas.
17	Google Workspace (Drive y Gmail externos)	Almacena documentos compartidos con terceros, correos con clientes y socios. Transmite datos entre empleados y partes externas vía Drive, Meet y Gmail corporativo.
18	Plataforma de soporte al cliente (Zendesk)	Almacena y procesa tickets de soporte, historial de conversaciones y datos de usuarios de claude.ai. Transmite comunicaciones entre el equipo de soporte y los clientes.
19	Azure Active Directory (AAD) externo	Almacena identidades de usuarios en entornos Microsoft Azure. Transmite tokens de autenticación y datos de acceso entre servicios de Azure y los sistemas de Anthropic.

20	Red de entrega de contenido (CDN) de modelos	Transmite actualizaciones de modelos, pesos cuantizados y binarios de inferencia entre los centros de datos de Anthropic y los proveedores cloud para despliegues distribuidos.
----	---	---

Activos Internos

Infraestructura, sistemas y recursos de información propios de Anthropic, gestionados directamente bajo las políticas de seguridad del SGSI. Son objeto de control total por parte de la organización.

#	Activo	Descripción
1	Pesos y checkpoints de modelos Claude	Activo más crítico del SGSI. Almacenan los parámetros entrenados de cada versión de Claude. Procesados durante inferencia y entrenamiento; transmitidos entre clusters con cifrado AES-256 en tránsito.
2	Datasets de entrenamiento preprocesados	Almacenan el corpus de texto filtrado, anotado y clasificado usado para entrenar modelos Claude. Procesados por los pipelines de entrenamiento en clusters Trainium2 (Project Rainier).
3	Repositorios internos de código fuente	Almacenan el código de los modelos Claude, infraestructura, herramientas internas y Constitutional AI. Transmitidos a servidores de CI/CD para compilación, pruebas y despliegue.
4	Bases de datos internas de investigación	Almacenan resultados de experimentos, métricas de evaluación, hallazgos de red-teaming y datos de alineación no publicados. Procesadas exclusivamente por el equipo de investigación.
5	Registros de auditoría y logs del SIEM	Almacenan eventos de seguridad, accesos a sistemas, cambios de configuración y anomalías detectadas. Procesados por la plataforma SIEM para correlación y análisis forense.
6	Gestor interno de secretos y credenciales	Almacena claves API, tokens OAuth, certificados TLS y credenciales de servicios. Transmite secretos cifrados a sistemas autorizados bajo demanda con acceso por roles definidos.
7	Pipeline interno de entrenamiento de modelos	Procesa datasets de entrenamiento a través de múltiples etapas (tokenización, batching, gradientes). Transmite checkpoints intermedios entre nodos del cluster Trainium2.
8	Plataforma interna de red-teaming y evals	Almacena resultados de evaluaciones adversariales, benchmarks de seguridad y pruebas de alineación. Procesa prompts de ataque y respuestas del modelo antes de cada lanzamiento.
9	Sistema IAM corporativo (control de accesos)	Almacena roles, permisos y ciclo de vida de cuentas de los ~1,100 empleados. Procesa solicitudes de acceso y transmite políticas de autorización a todos los sistemas internos.
10	Documentación técnica clasificada	Almacena arquitectura de sistemas, diseño de modelos, procedimientos operativos y hallazgos de seguridad internos. Acceso restringido por rol con registro de descarga en auditoría.
11	Red LAN corporativa y switches internos	Transmite datos entre todos los sistemas internos de la sede en San Francisco. Procesa el tráfico segmentado por VLAN entre equipos de ingeniería, seguridad e investigación.
12	VPN corporativa	Transmite de forma cifrada el tráfico de empleados remotos hacia los sistemas internos. Procesa autenticación MFA y registra metadatos de conexión para auditoría de accesos.
13	Servidores internos de desarrollo y staging	Almacenan versiones en prueba de modelos y plataformas antes de producción. Procesan experimentos, pruebas de integración y validaciones de seguridad de nuevas versiones de Claude.
14	Sistema de correo corporativo	Almacena y transmite comunicaciones internas entre empleados, equipos y con terceros. Procesa adjuntos, metadatos de mensajes y aplica filtros DLP para prevenir fuga de datos.

15	Plataforma de mensajería interna (Slack)	Transmite mensajes, archivos y notificaciones entre equipos. Almacena historial de conversaciones internas, incluyendo canales de respuesta a incidentes y discusiones de seguridad.
16	Sistema de respaldo y recuperación (backups)	Almacena copias cifradas de datos críticos: pesos de modelos, código fuente, bases de datos y configuraciones. Procesa verificaciones de integridad y transmite datos en restauraciones.
17	Sistema EDR y endpoint security	Almacena telemetría de seguridad de los ~1,100 dispositivos corporativos. Procesa comportamiento de procesos, conexiones de red y accesos a archivos en tiempo real para detectar amenazas en endpoints.
18	Sistema de gestión de vulnerabilidades	Almacena hallazgos de escaneos de código, dependencias e infraestructura. Procesa priorización de CVEs y transmite reportes al equipo de seguridad para remediación.
19	Laptops y workstations del personal	Almacenan localmente código, credenciales de sesión y datos de trabajo de los ~1,100 empleados. Transmiten datos hacia sistemas internos vía VPN; sujetos a cifrado de disco completo.
20	Sistema de gestión de tickets internos (Jira)	Almacena solicitudes de acceso, incidentes, cambios y no conformidades del SGSI. Procesa flujos de aprobación y transmite notificaciones entre equipos de seguridad y operaciones.

Sección 5 - LIDERAZGO

Política de Seguridad de la Información (PSI) con 20 políticas y matrices RACI

ANTHROPIC

01

Amazon Web Services (AWS)

Política de Gestión de Accesos e Identidades en Infraestructura Cloud

ESTÁNDAR

Implementar MFA para todas las cuentas IAM con acceso a Amazon Bedrock y clusters Trainium.

DIRECTRIZ

Auditar trimestralmente los permisos IAM para identificar cuentas con privilegios excesivos o inactivas.

PROCEDIMIENTO

Todo acceso nuevo debe ser solicitado por el líder de equipo, aprobado por el CISO y documentado en el sistema de tickets.

LÍNEA BASE

Rotar credenciales cada 90 días y usar contraseñas de mínimo 16 caracteres.

01 Matriz RACI — Amazon Web Services (AWS)

	Responsable	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso	R	A	-	I	-
Aprobar acceso	I	R	A	I	-
Auditar permisos IAM	I	R	A	C	I
Rotar credenciales	R	C	A	I	-
Documentar en tickets	R	C	A	I	I

02

Google Cloud Platform (GCP)

Política de Control de Accesos y Roles en Plataformas Cloud

ESTÁNDAR

Implementar MFA obligatorio para todos los usuarios con acceso a Vertex AI y servicios de GCP.

DIRECTRIZ

Revisar mensualmente los roles y permisos en GCP IAM, eliminando accesos no utilizados en los últimos 30 días.

PROCEDIMIENTO

Los accesos deben solicitarse mediante formulario formal, con aprobación del responsable técnico y registro en bitácora.

LÍNEA BASE

Las cuentas de servicio deben renovar claves cada 90 días y seguir el principio de mínimo privilegio.

02 Matriz RACI — Google Cloud Platform (GCP)

	Responsable	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso GCP	R	A	-	I	-
Aprobar acceso	I	R	A	C	-
Revisar roles mensual	I	R	A	C	I
Rotar claves de servicio	R	C	A	I	-
Eliminar accesos no usados	I	R	A	C	I

03

Microsoft Azure

Política de Autenticación y Gestión de Identidades Corporativas

ESTÁNDAR

Habilitar Azure Active Directory MFA para todos los usuarios con acceso a recursos de cómputo e inferencia.

DIRECTRIZ

Realizar auditorías bimestrales de roles y grupos en Azure AD para detectar permisos huérfanos.

PROCEDIMIENTO

Nuevos accesos requieren solicitud formal, validación del área de seguridad y activación supervisada.

LÍNEA BASE

Cambiar contraseña cada 90 días; las cuentas sin actividad 30 días quedan suspendidas automáticamente.

03 Matriz RACI — Microsoft Azure

	Responsible	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso Azure	R	A	-	I	-
Validar y aprobar	I	C	A	R	-
Auditoría bimestral AD	I	R	A	C	I
Suspender cuentas inactivas	-	R	A	C	I
Rotar contraseñas	R	C	A	I	-

04

Proyecto Rainier (Trainium2)

Política de Acceso Restringido a Infraestructura de Entrenamiento de Modelos

ESTÁNDAR

Restringir acceso al cluster Trainium2 exclusivamente al equipo de entrenamiento de modelos, con MFA obligatorio.

DIRECTRIZ

Auditar semanalmente los registros de acceso al cluster para detectar accesos anómalos o no autorizados.

PROCEDIMIENTO

El acceso debe ser aprobado por el Director de Infraestructura y revisado cada 30 días para confirmar vigencia.

LÍNEA BASE

Credenciales de acceso al cluster deben rotarse cada 90 días y nunca compartirse entre usuarios.

04 Matriz RACI — Proyecto Rainier (AWS — Trainium2)

	Responsible	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso cluster	R	A	C	I	-
Aprobar acceso	I	C	A	R	-
Auditoría semanal de logs	I	R	A	C	I
Revisión 30 días	I	C	A	R	I
Rotar credenciales	R	C	A	I	-

05

Puerta de Enlace IA Cloudflare

Política de Administración Segura de Gateways de Inteligencia Artificial

ESTÁNDAR

Implementar MFA para todos los usuarios con acceso al panel de administración de Cloudflare AI Gateway.

DIRECTRIZ

Revisar mensualmente las reglas de enrutamiento y los permisos de administración configurados en el gateway.

PROCEDIMIENTO

Cualquier cambio de configuración o nuevo acceso debe ser aprobado por el equipo de operaciones y registrado con marca de tiempo.

LÍNEA BASE

Las claves API deben rotarse cada 90 días y almacenarse únicamente en el gestor de secretos autorizado.

05 Matriz RACI — Puerta de Enlace IA Cloudflare

	Responsible	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso gateway	R	A	C	-	I
Aprobar cambios de config	I	C	A	-	R
Revisar reglas mensual	I	R	A	-	C
Rotar claves API	R	C	A	-	I
Registrar cambios	R	C	A	-	R

06

API Pública de Claude

Política de Gestión del Ciclo de Vida de Claves API

ESTÁNDAR

Todas las claves API deben generarse con permisos mínimos y estar asociadas a un usuario o sistema identificado.

DIRECTRIZ

Auditar trimestralmente las claves API activas, revocando las que no hayan tenido actividad en 60 días.

PROCEDIMIENTO

La generación de nuevas claves debe realizarse desde el portal oficial, con registro del propósito y responsable asignado.

LÍNEA BASE

Rotar claves cada 90 días; las comprometidas deben revocarse en máximo 2 horas tras su detección.

06 Matriz RACI — API Pública de Claude

	Responsable	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Generar claves API	R	A	C	I	-
Auditar claves activas	I	R	A	C	I
Revocar claves inactivas	I	R	A	C	I
Respuesta a compromiso	R	C	A	R	I
Rotar claves 90 días	R	C	A	I	-

07

Snowflake

Política de Acceso y Privilegios en Plataformas de Datos

ESTÁNDAR

Implementar MFA para todos los usuarios con acceso a la integración de Snowflake en el Claude Marketplace.

DIRECTRIZ

Revisar bimestralmente los roles de Snowflake por usuario, asegurando el principio de mínimo privilegio.

PROCEDIMIENTO

El acceso debe solicitarse con justificación de negocio, aprobarse por el responsable de datos y activarse con perfil restringido.

LÍNEA BASE

Contraseñas cambian cada 90 días; las cuentas de servicio usan autenticación por certificado.

07 Matriz RACI — Snowflake

	Responsable	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso	R	C	A	I	-
Aprobar y activar acceso	I	C	A	R	-
Revisión bimestral roles	I	R	A	C	I
Gestionar certificados	-	R	A	C	I
Rotar contraseñas	R	C	A	I	-

08

Broadcom — Infraestructura de Red

Política de Administración Segura de Infraestructura de Red

ESTÁNDAR

Implementar MFA y acceso basado en roles para todos los administradores con acceso a la infraestructura de red Broadcom.

DIRECTRIZ

Auditar mensualmente los accesos administrativos a equipos de red, revisando cambios de configuración en logs.

PROCEDIMIENTO

Solicitudes de acceso deben pasar por aprobación del equipo de redes y documentarse en el sistema de cambios.

LÍNEA BASE

Las credenciales de administración deben rotarse cada 90 días y no reutilizarse entre dispositivos.

08 Matriz RACI — Broadcom — Infraestructura de Red

	Responsable	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso red	R	A	C	I	-
Aprobar acceso	I	C	A	R	-
Auditoría mensual logs	I	R	A	C	I
Documentar cambios	R	C	A	R	I
Rotar credenciales	R	C	A	I	-

09

DNS y CDN Externo

Política de Control y Monitoreo de Servicios de Resolución y Distribución

ESTÁNDAR

Implementar MFA para todos los accesos al panel de administración de DNS y CDN que soportan claud.ai y la API.

DIRECTRIZ

Revisar mensualmente registros DNS y reglas CDN para detectar configuraciones no autorizadas o modificaciones inesperadas.

PROCEDIMIENTO

Cambios en DNS/CDN deben solicitarse formalmente, aprobarse por infraestructura y ejecutarse con ventana de cambio programado.

LÍNEA BASE

Credenciales rotadas cada 90 días; alertas habilitadas ante cualquier modificación de registros críticos.

09 Matriz RACI — DNS y CDN Externo

	Responsable	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar cambio DNS/CDN	R	A	C	I	-
Aprobar cambio	I	C	A	R	-
Revisar registros mensual	I	R	A	C	I
Configurar alertas	-	R	A	C	I
Rotar credenciales	R	C	A	I	-

10

Inteligencia de Amenazas

Política de Acceso a Fuentes de Inteligencia de Ciberseguridad

ESTÁNDAR

Restringir el acceso a feeds de inteligencia de amenazas e IOCs al equipo de seguridad, con MFA obligatorio.

DIRECTRIZ

Auditar trimestralmente los usuarios con acceso a plataformas de inteligencia, eliminando accesos de personal fuera del equipo.

PROCEDIMIENTO

El acceso debe solicitarse con justificación de rol, ser aprobado por el CISO y revisarse semestralmente.

LÍNEA BASE

Credenciales rotadas cada 90 días y nunca compartidas entre analistas.

10 Matriz RACI — Inteligencia de Amenazas Externas

	Responsible	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso	R	C	A	I	-
Aprobar acceso (CISO)	I	I	A	R	-
Auditoría trimestral	I	R	A	C	I
Revisión semestral	I	C	A	R	I
Rotar credenciales	R	C	A	I	-

11

Laptops y Workstations del Personal

Política de Seguridad de Dispositivos de Usuario Final

ESTÁNDAR

Todos los dispositivos deben tener MFA habilitado para el inicio de sesión, ya sea biométrica o token físico.

DIRECTRIZ

Auditar semestralmente el inventario de dispositivos activos, verificando que solo empleados vigentes tengan acceso activo.

PROCEDIMIENTO

Al incorporar un empleado se asigna dispositivo con perfil mínimo; al salir, debe formatearse y darse de baja en 24 horas.

LÍNEA BASE

Cambiar contraseña local cada 90 días; bloqueo automático tras 5 minutos de inactividad.

11 Matriz RACI — Laptops y Workstations del Personal

	Responsible	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Asignar dispositivo	-	A	C	R	I
Configurar perfil mínimo	-	R	A	C	I
Baja y formateo	-	R	A	C	R
Auditoría semestral	-	R	A	C	I
Rotar contraseñas	R	C	A	I	-

12

Servidores de Desarrollo

Política de Acceso Controlado a Entornos de Desarrollo y Staging

ESTÁNDAR

Implementar MFA para todos los accesos a servidores de desarrollo y staging de modelos.

DIRECTRIZ

Revisar mensualmente los usuarios con acceso SSH/RDP a servidores de desarrollo, revocando accesos de proyectos finalizados.

PROCEDIMIENTO

Acceso solicitado por ticket, aprobado por el líder técnico y asignado con fecha de vencimiento definida.

LÍNEA BASE

Credenciales rotadas cada 90 días; acceso root solo bajo sesión supervisada y registrada.

12 Matriz RACI — Servidores Internos de Desarrollo

	Responsable	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso servidor	R	A	C	I	-
Aprobar y asignar	I	C	A	R	-
Revisión mensual accesos	I	R	A	C	I
Revocar accesos vencidos	I	R	A	C	I
Supervisar acceso root	-	R	A	C	I

13

Red LAN Corporativa

Política de Seguridad y Control de Acceso a la Red Interna

ESTÁNDAR

El acceso a la LAN debe requerir autenticación por certificado de dispositivo más credenciales de usuario con MFA.

DIRECTRIZ

Auditar trimestralmente los dispositivos conectados a la LAN, identificando equipos no autorizados o con comportamiento anómalo.

PROCEDIMIENTO

Todo nuevo dispositivo debe pasar por registro y aprobación de TI antes de conectarse a la red corporativa.

LÍNEA BASE

Credenciales de red renovadas cada 90 días; dispositivos inactivos 15 días retirados automáticamente.

13 Matriz RACI — Red LAN Corporativa

	Responsable	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Registrar nuevo dispositivo	R	A	C	R	I
Aprobar conexión	-	C	A	R	-
Auditoría trimestral LAN	-	R	A	C	I
Retirar equipos inactivos	-	R	A	C	I
Renovar credenciales	R	C	A	I	-

14

VPN Corporativa

Política de Acceso Remoto Seguro mediante VPN

ESTÁNDAR

El acceso VPN debe requerir MFA obligatorio, combinando contraseña con token de un solo uso (OTP).

DIRECTRIZ

Revisar mensualmente los registros de conexión VPN para detectar accesos desde ubicaciones inusuales o fuera de horario.

PROCEDIMIENTO

Solicitud tramitada por TI, con aprobación del responsable del empleado y configuración de perfil de acceso mínimo.

LÍNEA BASE

Contraseñas VPN cambiadas cada 90 días; sesiones inactivas 30 minutos cerradas automáticamente.

14 Matriz RACI — VPN Corporativa

	Responsable	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso VPN	R	A	C	R	-
Aprobar y configurar	-	C	A	R	-
Revisar logs mensual	-	R	A	C	I
Cerrar sesiones inactivas	-	R	A	C	I
Rotar contraseñas	R	C	A	I	-

15

Repositorios Internos de Código

Política de Gestión de Accesos a Repositorios de Código Fuente

ESTÁNDAR

Implementar MFA para todos los usuarios con acceso a repositorios privados de código de Claude y plataformas internas.

DIRECTRIZ

Auditar mensualmente los permisos de lectura/escritura, asegurando que solo personal activo del proyecto tenga acceso.

PROCEDIMIENTO

Acceso solicitado con proyecto y nivel de permiso requerido, aprobado por líder técnico y registrado en gestión de accesos.

LÍNEA BASE

Tokens de acceso personal rotados cada 90 días; acceso de ex-empleados revocado en primeras 2 horas tras baja.

15 Matriz RACI — Repositorios Internos de Código

	Responsible	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso repo	R	A	C	I	-
Aprobar nivel de permiso	I	C	A	R	-
Auditoría mensual permisos	I	R	A	C	I
Revocar acceso al salir	-	R	A	C	R
Rotar tokens	R	C	A	I	-

16

Documentación Técnica Interna

Política de Protección y Acceso a Documentación Clasificada

ESTÁNDAR

Restringir acceso a documentación de arquitectura y diseño de modelos al personal con necesidad justificada, con MFA obligatorio.

DIRECTRIZ

Revisar semestralmente los permisos de acceso a documentación sensible, eliminando accesos de empleados que cambiaron de área.

PROCEDIMIENTO

Acceso solicitado con justificación de proyecto, aprobado por responsable del área y registrado en el sistema de control.

LÍNEA BASE

Credenciales renovadas cada 90 días; documentos descargados registrados en el registro de auditoría.

16 Matriz RACI — Documentación Técnica Interna

	Responsable	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso docs	R	A	C	I	-
Aprobar con justificación	I	C	A	R	-
Revisión semestral	I	R	A	C	I
Registrar descargas	-	R	A	C	I
Renovar credenciales	R	C	A	I	-

17

Sistema de Correo Corporativo

Política de Uso Seguro del Sistema de Correo Electrónico Corporativo

ESTÁNDAR

Implementar MFA para todos los usuarios del sistema de correo corporativo, sin excepción de rol o jerarquía.

DIRECTRIZ

Auditar trimestralmente las cuentas de correo activas, desactivando cuentas de empleados que ya no pertenecen a la organización.

PROCEDIMIENTO

Nuevas cuentas solicitadas por RRHH al incorporar empleado; la baja debe ejecutarse el mismo día de la salida.

LÍNEA BASE

Contraseñas cambiadas cada 90 días; reenvío automático a cuentas externas deshabilitado por defecto.

17 Matriz RACI — Sistema de Correo Corporativo

	Responsible	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Crear cuenta de correo	-	R	A	I	C
Dar de baja cuenta	-	R	A	I	C
Auditoría trimestral	-	R	A	C	I
Configurar MFA	R	C	A	I	-
Deshabilitar reenvío	-	R	A	C	I

18

Plataforma de Mensajería Interna

Política de Seguridad en Plataformas de Comunicación Interna

ESTÁNDAR

Habilitar MFA para todos los usuarios de la plataforma de mensajería, incluyendo bots e integraciones automatizadas.

DIRECTRIZ

Revisar mensualmente los canales privados y permisos, asegurando que no haya usuarios externos con acceso a canales sensibles.

PROCEDIMIENTO

Acceso otorgado automáticamente al incorporar empleado; debe revocarse dentro de las primeras 4 horas tras la baja.

LÍNEA BASE

Contraseñas rotadas cada 90 días; sesiones en dispositivos no reconocidos cerradas y notificadas al usuario.

18 Matriz RACI — Plataforma de Mensajería Interna

	Responsible	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Activar cuenta mensajería	-	R	A	I	C
Revocar acceso (4h)	-	R	A	I	C
Revisar canales mensual	-	R	A	C	I
Gestionar integraciones	-	R	A	C	I
Cerrar sesiones sospechosas	R	C	A	I	-

19

Bases de Datos de Investigación

Política de Acceso y Protección de Datos de Investigación

ESTÁNDAR

Restringir acceso a bases de datos de investigación exclusivamente al equipo investigador, con MFA y acceso por roles definidos.

DIRECTRIZ

Auditar mensualmente los accesos, revisando consultas inusuales en volumen o en horario fuera de lo normal.

PROCEDIMIENTO

Acceso solicitado con descripción del proyecto, aprobado por líder de investigación y asignado con fecha de vencimiento acorde al proyecto.

LÍNEA BASE

Credenciales rotadas cada 90 días; acceso directo a producción prohibido, solo vía entorno controlado.

19 Matriz RACI — Bases de Datos de Investigación

	Responsible	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso BD	R	C	A	R	-
Aprobar con descripción	I	C	A	R	-
Auditoría mensual accesos	I	R	A	C	I
Detectar consultas anómalas	-	R	A	C	I
Rotar credenciales	R	C	A	I	-

20

Sistema de Respaldo y Recuperación

Política de Gestión Segura de Copias de Seguridad y Recuperación

ESTÁNDAR

Implementar MFA para todos los administradores con acceso al sistema de copias de seguridad y planes de recuperación ante desastres.

DIRECTRIZ

Auditar trimestralmente los permisos del sistema de respaldo, asegurando que solo infraestructura tenga permisos de escritura y restauración.

PROCEDIMIENTO

Restauración solicitada formalmente, aprobada por el CISO y ejecutada bajo supervisión de al menos dos administradores.

LÍNEA BASE

Credenciales de administración rotadas cada 90 días; intentos de acceso fallidos generan alerta inmediata al equipo de seguridad.

20 Matriz RACI — Sistema de Respaldo y Recuperación

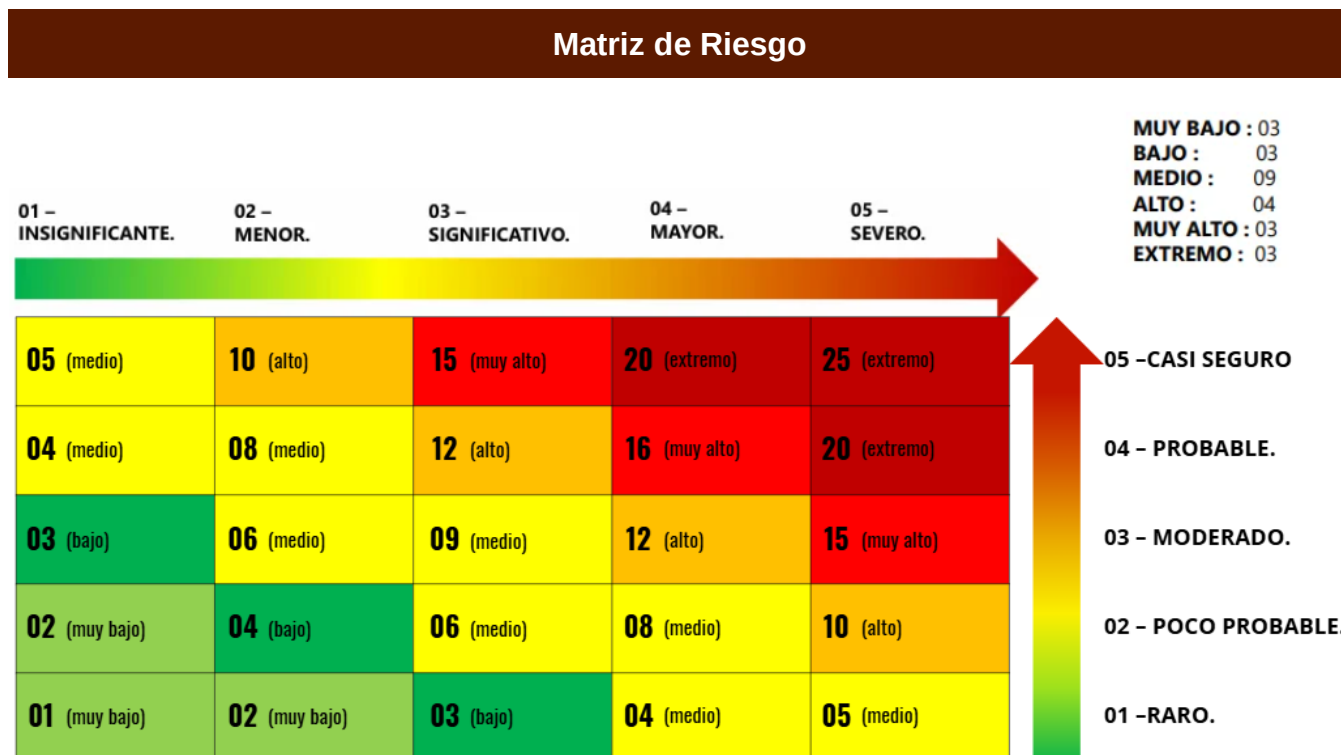
	Responsible	Accountable	Consulted	Informed	
Actividad / Proceso	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar restauración	R	C	A	R	-
Aprobar restauración (CISO)	I	I	A	R	-
Ejecutar bajo supervisión	-	R	A	C	I
Auditoría trimestral	-	R	A	C	I
Gestionar alertas de fallo	-	R	A	C	I

Sección 6 - PLANIFICACIÓN

Matriz de riesgo, evaluación y tratamiento de riesgos por activo

ANTHROPIC

Identificación y Análisis de Riesgos



Anexo a Matriz de Riesgo — 20 Políticas de Seguridad

1. Amazon Web Services (AWS)

Política de Gestión de Accesos e Identidades en Infraestructura Cloud



[1]

Riesgo: Credenciales IAM comprometidas permiten escalar privilegios hacia clusters de entrenamiento y buckets S3 con datasets. **(Escalada de privilegios en nube)**

Probabilidad: 05 – Casi seguro

Impacto: 05 – Severo

Nivel de Riesgo: **Extremo (25)**

2. Google Cloud Platform (GCP)

Política de Control de Accesos y Roles en Plataformas Cloud



[2]

Riesgo: Claves de cuentas de servicio filtradas exponen pipelines de datos y modelos alojados en Vertex AI. **(IAM misconfiguration / Abuso de cuentas de servicio)**

Probabilidad: 04 – Probable

Impacto: 05 – Severo

Nivel de Riesgo: **Extremo (20)**

3. Microsoft Azure

Política de Autenticación y Gestión de Identidades Corporativas



[3]

Riesgo: Roles de Azure AD huérfanos de empleados dados de baja permiten autenticación legítima a entornos híbridos corporativos. **(Reutilización de identidades huérfanas)**

Probabilidad: 04 – Probable

Impacto: 04 – Mayor

Nivel de Riesgo: **Muy alto (16)**

4. Proyecto Rainier (Trainium2)

Política de Acceso Restringido a Infraestructura de Entrenamiento de Modelos



[4]

Riesgo: Acceso al clúster permite extraer pesos de modelos en entrenamiento o inyectar datos envenenados en corridas irrepetibles. **(Robo de modelo / Data poisoning)**

Probabilidad: 05 – Casi seguro

Impacto: 05 – Severo

Nivel de Riesgo: **Extremo (25)**

5. Puerta de Enlace IA Cloudflare

Política de Administración Segura de Gateways de Inteligencia Artificial



[5]

Riesgo: Modificación de reglas de enrutamiento permite redirigir tráfico de API hacia endpoints maliciosos o eludir controles establecidos. **(API traffic hijacking)**

Probabilidad: 03 – Moderado

Impacto: 04 – Mayor

Nivel de Riesgo: **Alto (12)**

6. API Pública de Claude

Política de Gestión del Ciclo de Vida de Claves API



[6]

Riesgo: Claves API expuestas en repositorios públicos habilitan consumo masivo no autorizado y ataques de prompt injection a escala. **(API key leakage / Prompt injection)**

Probabilidad: 05 – Casi seguro

Impacto: 04 – Mayor

Nivel de Riesgo: **Extremo (20)**

7. Snowflake

Política de Acceso y Privilegios en Plataformas de Datos



[7]

Riesgo: Cuenta privilegiada comprometida permite exfiltrar datasets de clientes en bulk mediante consultas SQL sin alertar controles perimetrales. **(Exfiltración de datos vía credenciales comprometidas)**

Probabilidad: 04 – Probable

Impacto: 04 – Mayor

Nivel de Riesgo: **Muy Alto (16)**

8. Infraestructura de Red

Política de Administración Segura de Infraestructura de Red



[8]

Riesgo: Acceso a dispositivos de red permite modificar tablas de enrutamiento e interceptar tráfico interno entre datacenters. **(Manipulación de routing / MitM interno)**

Probabilidad: 02 – Poco probable

Impacto: 05 – Severo

Nivel de Riesgo: **Alto (10)**

9. DNS / CDN

Política de Control y Monitoreo de Servicios de Resolución y Distribución



[9]

Riesgo: Credenciales de panel comprometidas permiten redirigir usuarios a sitios fraudulentos o dejar Claude inaccesible durante la propagación DNS. **(DNS hijacking)**

Probabilidad: 04 – Probable

Impacto: 05 – Severo

Nivel de Riesgo: **Extremo (20)**

10. Fuentes de Inteligencia Cyber

Política de Acceso a Fuentes de Inteligencia de Ciberseguridad



[10]

Riesgo: Exposición de feeds de IOCs y reglas de detección revela qué TTPs ya son conocidos, permitiendo evadir controles vigentes. **(Fuga de inteligencia defensiva)**

Probabilidad: 03 – Moderado

Impacto: 04 – Mayor

Nivel de Riesgo: **Alto (12)**

11. Dispositivos de Usuario Final

Política de Seguridad de Dispositivos de Usuario Final



[11]

Riesgo: Dispositivo robado sin cifrado de disco expone credenciales almacenadas y tokens de acceso cloud sin requerir ataque remoto. **(Robo de dispositivo / Acceso físico)**

Probabilidad: 01 – Raro

Impacto: 05 – Severo

Nivel de Riesgo: **Medio (05)**

12. Entornos de Desarrollo y Staging

Política de Acceso Controlado a Entornos de Desarrollo y Staging



[12]

Riesgo: Acceso a staging expone configuraciones de producción reutilizadas y versiones preliminares de modelos como vector de pivote. **(Pivoting desde entorno de desarrollo)**

Probabilidad: 03 – Moderado

Impacto: 05 – Severo

Nivel de Riesgo: **Muy Alto (15)**

13. Red Interna Corporativa

Política de Seguridad y Control de Acceso a la Red Interna



[13]

Riesgo: Dispositivo no gestionado en red interna permite reconocimiento pasivo y movimiento lateral hacia activos críticos. **(Rogue device / Movimiento lateral)**

Probabilidad: 03 – Moderado

Impacto: 05 – Severo

Nivel de Riesgo: **Muy Alto (15)**

14. VPN Corporativa

Política de Acceso Remoto Seguro mediante VPN



[14]

Riesgo: Credenciales comprometidas sin MFA otorgan túnel cifrado a la red interna con acceso equivalente al de un empleado legítimo. **(Credential stuffing / Acceso remoto no autorizado)**

Probabilidad: 05 – Casi Seguro

Impacto: 04 – Mayor

Nivel de Riesgo: **Alto (20)**

15. Repositorios de Código Fuente

Política de Gestión de Accesos a Repositorios de Código Fuente



[15]

Riesgo: Acceso no autorizado permite extraer credenciales embebidas en IaC e inyectar código malicioso en builds de producción. **(Supply chain attack / Secret leakage)**

Probabilidad: 02 – Poco probable

Impacto: 04 – Mayor

Nivel de Riesgo: **Medio (08)**

16. Documentación Clasificada

Política de Protección y Acceso a Documentación Clasificada



[16]

Riesgo: Fuga de diagramas de red y diseño de seguridad entrega al atacante un mapa completo de la superficie de ataque. **(Reconocimiento interno)**

Probabilidad: 01 – Raro

Impacto: 04 – Mayor

Nivel de Riesgo: **Medio (04)**

17. Correo Electrónico Corporativo

Política de Uso Seguro del Sistema de Correo Electrónico Corporativo



[17]

Riesgo: Cuenta comprometida permite suplantar identidades ejecutivas y escalar ataques de ingeniería social internamente. **(Phishing / Business Email Compromise)**

Probabilidad: 05 – Casi seguro

Impacto: 04 – Mayor

Nivel de Riesgo: **Muy alto (20)**

18. Plataformas de Comunicación

Política de Seguridad en Plataformas de Comunicación Interna



[18]

Riesgo: Acceso a canales privados expone credenciales compartidas informalmente y decisiones estratégicas de equipos de investigación. (**Insider threat / Acceso indebido**)

Probabilidad: 01 – Raro

Impacto: 03 – Significativo

Nivel de Riesgo: **Bajo (03)**

19. Datos de Investigación

Política de Acceso y Protección de Datos de Investigación



[19]

Riesgo: Exfiltración de datasets y resultados experimentales representa pérdida de ventaja competitiva y violación de acuerdos de confidencialidad. (**Exfiltración de propiedad intelectual**)

Probabilidad: 03 – Moderado

Impacto: 03 – Significativo

Nivel de Riesgo: **Medio (9)**

20. Copias de Seguridad y Recuperación

Política de Gestión Segura de Copias de Seguridad y Recuperación



[20]

Riesgo: Cifrado o borrado de respaldos convierte incidentes recuperables en pérdidas permanentes de datos críticos. (**Ransomware / Destrucción de respaldos**)

Probabilidad: 03 – Moderado

Impacto: 05 – Severo

Nivel de Riesgo: **Bajo (15)**

Asignación a Matriz de Riesgo



Sección 7 - SOPORTE

Competencia, concienciación y comunicación en el SGSI

ANTHROPIC

MINUTA DE REUNIÓN

Sistema de Gestión de Seguridad de la Información (SGSI)

1. Datos Generales de la Reunión

Proyecto:	Implementación SGSI — Anthropic
Tema:	Revisión de Cláusulas 1–6: Alcance, Contexto, Liderazgo y Planificación
Fecha:	Martes, 18 de Mayo de 2026
Hora:	09:00 – 09:45 hrs (45 minutos)
Modalidad:	Presencial / Videoconferencia híbrida
Ubicación:	Sala de Juntas — 548 Market St, San Francisco, California, Estados Unidos
Facilitador:	CISO / Líder del Proyecto SGSI
Código minuta:	SGSI-MIN-2026-001

2. Agenda — Distribución de 45 Minutos

#	Tema	Responsable	Tiempo	Hora
1	Bienvenida y verificación de quórum	Facilitador	5 min	09:00 – 09:05
2	Contexto y alcance del SGSI (Cláusulas 1–3)	CISO / Líder SGSI	8 min	09:05 – 09:13
3	Contexto de la organización (Cláusula 4)	CISO / Líder SGSI	8 min	09:13 – 09:21
4	Liderazgo y compromiso (Cláusula 5)	Alta Dirección	8 min	09:21 – 09:29
5	Planificación: riesgos y objetivos (Cláusula 6)	CISO / Líder SGSI	10 min	09:29 – 09:39
6	Compromisos, acuerdos y cierre	Todos	6 min	09:39 – 09:45

3. Resumen de Discusión por Cláusula

Tema / Cláusula	Puntos discutidos / Decisiones
Cláusulas 1–3 Alcance y referencias	- Se confirmó el alcance del SGSI: infraestructura tecnológica, datos de clientes y procesos críticos de Anthropic. - Se repasaron los términos normativos ISO/IEC 27001:2022 aplicables.
Cláusula 4 Contexto de la organización	- Se identificaron partes interesadas clave: reguladores, clientes corporativos, socios tecnológicos y empleados. - Se discutieron factores internos (cultura, procesos) y externos (regulación, competencia) que afectan el SGSI. - Pendiente: actualizar el análisis FODA de seguridad.

Tema / Cláusula	Puntos discutidos / Decisiones
Cláusula 5 Liderazgo	- Alta Dirección reafirmó su compromiso con la política de SI. - Se revisaron roles y responsabilidades del CISO y del equipo de seguridad. - Se acordó comunicar la política actualizada a toda la organización antes del 15-Jun-2026.
Cláusula 6 Planificación	- Se presentó la metodología de valoración de riesgos y el criterio de aceptación. - Se revisaron controles existentes vs. Anexo A (ISO 27001:2022). - Se establecieron objetivos de SI medibles para Q3-2026 por unidad funcional.

4. Acuerdos y Compromisos

#	Acuerdo / Acción	Responsable	Fecha límite
1	Revisar y aprobar el alcance formal del SGSI (Cláusula 4.3)	CISO	30-Jun-2026
2	Confirmar partes interesadas internas y externas relevantes	CISO / Dirección	15-Jun-2026
3	Validar la política de seguridad de la información (Cláusula 5.2)	Alta Dirección	15-Jun-2026
4	Actualizar el registro de riesgos con criterios de aceptación (Cláusula 6.1)	CISO / Analista SI	30-Jun-2026
5	Definir y documentar los objetivos de SI por área (Cláusula 6.2)	Líderes de área	15-Jul-2026
6	Programar siguiente sesión de revisión del SGSI	Facilitador	10-Jun-2026

5. Próxima Reunión

Fecha propuesta:	Martes, 23 de junio de 2026
Hora:	09:00 – 09:45 hrs
Tema:	Revisión SGSI — Sección 7: Soporte (Recursos, Competencias, Comunicación y Documentación)
Ubicación:	Sala de Juntas — 548 Market St, San Francisco, California, Estados Unidos

Facilitador / CISO	Representante Dirección	Secretario
Nombre: _____	Nombre: _____	Nombre: _____

¿Por Qué Necesitamos un SGSI?

10M+

usuarios activos

Protegemos Datos Reales

Millones de conversaciones, claves API y datos personales (PII) viajan por nuestra infraestructura. Una brecha afecta a personas reales y destruye la confianza.

180+

países operados

Cumplimiento Legal Global

Operamos bajo GDPR, CCPA, EU AI Act e HIPAA simultáneamente. El incumplimiento implica multas millonarias y suspensión de operaciones.

\$18B

valoración en riesgo

Protección del Negocio

Los pesos de nuestros modelos son el activo más valioso de Anthropic. Sin controles, una exfiltración puede borrar años de investigación e inversión.

SOC 2

ya certificados

ISO 27001: El Siguiente Paso

Clientes Enterprise y reguladores exigen ISO 27001. Es el estándar que demuestra madurez en seguridad y abre puertas a nuevos mercados.

Sin un SGSI formal, no podemos garantizar que hacemos las cosas bien. Con ISO 27001, lo demostramos con evidencia.

Alcance

Refs.

Términos

Contexto

Liderazgo

Planificación

01

ALCANCE

Cláusula 1 — ¿Qué Protege Nuestro SGSI?

Todo sistema de gestión necesita límites claros. Aquí definimos exactamente qué activos y servicios están bajo nuestro paraguas de seguridad.



Desarrollo LLM

Entrenamiento y fine-tuning de modelos Claude



API Pública

api.anthropic.com · acceso a modelos para developers



Claude.ai

Plataforma Web, iOS y Android para usuarios finales



Claude Code

Agente de codificación en terminal e IDEs



Almacenamiento

Conversaciones, métricas y logs del sistema



Infraestructura

GCP + AWS multi-cloud · alta disponibilidad



Red-Teaming

Evaluación adversarial antes de cada lanzamiento



Sistemas Corp.

GitHub, Slack, Okta, SIEM corporativos

⚠ Exclusiones: infraestructura física cloud (GCP/AWS), BYOD no gestionados, apps de terceros sin evaluación de seguridad.

Alcance

Refs.

Términos

Contexto

Liderazgo

Planificación

02

Referencias Normativas · Cláusula 2

ISO 27001:2022	Principal · 10 cláusulas + 93 controles (Anexo A)
ISO 27002:2022	Guía de implementación de los 93 controles
ISO 27005:2022	Gestión de riesgos de seguridad de la información
ISO 27017:2015	Controles de seguridad en nube (GCP + AWS)
ISO 27018:2019	Protección de datos personales (PII) en la nube
ISO 27032:2023	Ciberseguridad · prompt injection, jailbreaking, cadena IA
NIST AI RMF 1.0	Gestión de riesgos específicos de sistemas de IA
GDPR / CCPA / HIPAA	Regulaciones de privacidad en 180+ países
EU AI Act 2024	Obligaciones de transparencia para modelos GPAI como Claude

03

Términos y Definiciones · Cláusula 3

SGSI Marco de políticas para gestionar riesgos de información	Activo de info. Pesos del modelo, conversaciones, claves API, código
Confidencialidad Info. no revelada a entidades no autorizadas	Integridad Exactitud y completitud de logs, pesos y respuestas
Disponibilidad API ≥99.9% SLA — RTO 4h / RPO 1h	Amenaza Jailbreaking, prompt injection, exfiltración de datos
Constitutional AI Metodología propia de alineación ética de Claude	Red-Teaming Evaluación adversarial antes de cada lanzamiento
Riesgo Efecto de la incertidumbre sobre los objetivos del SGSI	Brecha Divulgación no autorizada de datos o pesos del modelo

04

CONTEXTO

Cláusula 4 — Contexto de la Organización

Entender el entorno en el que opera Anthropic define qué debemos proteger, quién depende de esa protección y qué factores externos nos afectan.

ACTIVOS EXTERNOS (10)

- Amazon Web Services (AWS) — Amazon Bedrock + Trainium
- Google Cloud Platform (GCP) — Vertex AI
- Project Rainier — 500K chips Trainium2 (entrenamiento)
- Cloudflare AI Gateway — enrutamiento de tráfico API
- API Pública Claude (api.anthropic.com)
- Snowflake — integración Claude Marketplace
- Broadcom — infraestructura de red multi-GW
- DNS y CDN externos — disponibilidad de claude.ai
- Servicios de Inteligencia de Amenazas (IOCs, feeds)
- Sistema de facturación externo

ACTIVOS INTERNOS (10)

- Laptops y workstations del personal (~1,100 empleados)
- Servidores internos de desarrollo y staging
- Red LAN corporativa (San Francisco HQ)
- VPN corporativa (acceso remoto seguro)
- Repositorios internos de código fuente (privados)
- Documentación técnica interna (arquitectura, modelos)
- Sistema de correo corporativo
- Plataforma de mensajería interna (tipo Slack)
- Bases de datos de investigación (resultados, métricas)
- Sistema de respaldo y recuperación ante desastres

05

Cláusula 5 — Liderazgo, Política y Roles

POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN (PSI)

Anthropic se compromete a proteger la confidencialidad, integridad y disponibilidad de todos sus activos de información mediante un SGSI alineado con ISO 27001:2022. Esta política aplica a todos los empleados, contratistas y proveedores que accedan a sistemas o datos de la organización.

MATRIZ RACI — Ejemplo: AWS (Gestión de Accesos)

R = Responsable (ejecuta) A = Accountable (rinde cuentas) C = Consulted (consultado) I = Informed (informado)

Actividad	Usuario/Solicitante	TI / Operaciones	CISO / Seguridad	Líder Técnico	RRHH
Solicitar acceso	R	A	—	I	—
Aprobar acceso	I	R	A	I	—
Auditar permisos IAM	I	R	A	C	I
Rotar credenciales (90d)	R	C	A	I	—
Documentar en tickets	R	C	A	I	I

06

PLANIF.

Cláusula 6 — Planificación y Gestión de Riesgos

Identificar, evaluar y tratar cada riesgo antes de que ocurra. Aquí mostramos los riesgos más críticos identificados en nuestras 20 políticas funcionales.

Escalada de privilegios AWS

25

EXTREMO

P: 05 · I: 05

Tratamiento:

MFA + IAM auditoría trimestral + rotación 90d

Robo de modelo / Data poisoning

20

EXTREMO

P: 04 · I: 05

Tratamiento:

Acceso restringido Trainium2 + auditoría semanal

Claves API comprometidas

20

EXTREMO

P: 05 · I: 04

Tratamiento:

Permisos mínimos + revocación < 2h + rotación 90d

Phishing correo corporativo

20

EXTREMO

P: 05 · I: 04

Tratamiento:

MFA + SPF/DKIM/DMARC + simulacros trimestrales

Acceso no auth. a staging

20

EXTREMO

P: 04 · I: 05

Tratamiento:

MFA SSH + tickets con fecha de vencimiento

Secuestro DNS / CDN

20

EXTREMO

P: 04 · I: 05

Tratamiento:

MFA panel + alertas críticas + ventana de cambio

Alcance

Refs.

Términos

Contexto

Liderazgo

Planificación

Sección 8 - OPERACIÓN

Plan de tratamiento de riesgos: Sistema de Correo Corporativo

ANTHROPIC

Operación — Tratamiento del Riesgo de Seguridad de la Información

Política aplicada: Política de Uso Seguro del Sistema de Correo Electrónico Corporativo Riesgo tratado: Cuenta comprometida permite suplantar identidades ejecutivas y escalar ataques de ingeniería social internamente (Phishing / Business Email Compromise).

Matriz de Riesgo

PROBABILIDAD	IMPACTO	NIVEL DE RIESGO
05 — Casi seguro	04 — Mayor	EXTREMO (20)

Descripción del Riesgo

El sistema de correo electrónico corporativo @anthropic.com constituye un activo de información crítico que almacena y transmite comunicaciones internas entre los ~1,100 empleados, incluyendo decisiones ejecutivas, datos de investigación sensibles y coordinaciones de seguridad. La probabilidad de que una cuenta sea comprometida mediante phishing o Business Email Compromise (BEC) es clasificada como Casi seguro (5), dado que el grupo norcoreano GTG-DPRK-0421 documentado por Anthropic en agosto 2025 ya utilizaba Claude para generar lures de correo altamente personalizados. El impacto Mayor (4) refleja que una cuenta ejecutiva comprometida permite escalar lateralmente a sistemas de investigación, activos de modelos y comunicaciones del Board. El nivel de riesgo resultante es Extremo (5x4 = 20), lo que exige tratamiento inmediato dentro del marco de la Cláusula 8.

Ficha del Incidente

Fecha del incidente	14 de octubre de 2024 — 09:23 UTC
Activo afectado	Sistema de correo corporativo @anthropic.com — cuentas del equipo de Research y Safety
Vector de ataque	Spear-phishing por correo: mensajes generados con IA suplantando al CISO con solicitud urgente de validación de credenciales en portal externo
Tipo de riesgo	Business Email Compromise (BEC) — suplantación de identidad ejecutiva para escalar ingeniería social interna
Causa raíz	Ausencia de DMARC estricto en dominios secundarios; sin DLP activo en correo; simulacros de phishing no ejecutados en los últimos 6 meses
Alcance	3 empleados del equipo de Safety recibieron el correo; 1 accedió al enlace; autenticación bloqueada por MFA. Escalada interna no ejecutada.
Detección	Alerta SIEM a los 47 minutos por acceso desde IP de rango anómalo. El empleado notificó al equipo de seguridad de forma manual previo a la alerta.
Impacto operacional	Nulo en acceso real — MFA activo bloqueó el compromiso. Impacto en gobernanza: exposición de gaps en política de correo y entrenamiento.
Clasificación ISO	Incidente de confidencialidad e integridad — Cláusula 8.1 + ISO 27035 (Gestión de incidentes) + ISO 27032:2023 (ingeniería social)

Ciclo PDCA — Fase PLAN

Planificar: Con un riesgo clasificado como Extremo (20), la fase PLAN define los controles preventivos que deben implementarse para reducir la probabilidad de compromiso de cuentas ejecutivas y bloquear la escalada de ingeniería social interna.

① PLAN — Identificación y valoración del riesgo — Phishing / BEC

Riesgo identificado: Cuenta de correo @anthropic.com comprometida permite suplantar identidades ejecutivas (CEO, CISO, Presidenta) y escalar ataques de ingeniería social hacia empleados, proveedores y sistemas internos.

Probabilidad: 05 — Casi seguro: El grupo GTG-DPRK-0421 usa Claude activamente para generar lures de correo personalizados. La infraestructura de phishing de DPRK tiene historial documentado de atacar empresas de IA de alto perfil.

Impacto: 04 — Mayor: Una cuenta ejecutiva comprometida expone comunicaciones del Board, coordinadas de investigación clasificada, acceso a sistemas IAM y capacidad de autorizar transferencias o cambios de acceso.

Riesgo resultante: Extremo (20): $5 \times 4 = 20$. Requiere tratamiento inmediato sin tolerancia al riesgo residual no mitigado. Escala de aprobación: CISO + CEO.

Control (ISO A.6.3 — Concienciación): Programa trimestral de simulacros de phishing BEC con escenarios de suplantación de ejecutivos; formación diferenciada para Research, Safety y liderazgo. Resultado mínimo: tasa de clics < 2%.

Control (ISO A.8.23 — Filtrado de correo): DMARC policy=reject en todos los dominios @anthropic.com; SPF y DKIM estrictos; banner visible en correos de remitentes externos; filtro anti-spoofing de nombres de display ejecutivos.

Control (ISO A.8.5 — Autenticación segura): MFA obligatorio y verificado al 100% de cuentas; autenticación resistente a phishing (FIDO2/passkeys) para cuentas ejecutivas y de alta sensibilidad; revisión mensual automatizada.

Control (ISO A.5.25 — Gestión de incidentes): Botón de reporte de phishing integrado en cliente de correo; tiempo máximo de notificación al equipo de seguridad: 10 minutos; procedimiento de revocación de sesión en < 30 minutos.

Responsable: CISO + Equipo de Seguridad Corporativa + RRHH (coordinación de entrenamiento) · Aprobación: CEO

Ciclo PDCA — Fase DO

Hacer: Ejecutar los controles planificados e implementar las medidas de contención y respuesta operacional ante el incidente de BEC detectado.

② DO — Implementación de controles y respuesta operacional

Acción inmediata (0–30 min): Bloqueo preventivo de la cuenta del empleado afectado; revocación de todas las sesiones activas; forzado de re-autenticación con MFA en el dispositivo corporativo verificado.

Acción inmediata (0–1h): Aislamiento del dominio del portal de phishing en el filtro DNS corporativo y en las reglas del gateway de correo; alerta interna a todos los empleados describiendo el correo malicioso.

Acción inmediata (0–2h): Revisión forense de los logs de correo: identificación de los 3 destinatarios, trazabilidad del remitente falsificado, análisis de cabeceras DKIM/SPF del correo malicioso recibido.

Control DMARC implementado: Activación de DMARC policy=reject en los 3 dominios de correo corporativo de Anthropic; SPF y DKIM configurados en modo estricto; banner de advertencia activado para remitentes externos.

Control anti-BEC implementado: Regla de filtrado que detecta y bloquea correos donde el nombre de display corresponde a un ejecutivo de Anthropic pero el dominio del remitente es externo o no verificado.

Control MFA reforzado: Auditoría completa: verificación de MFA activo en el 100% de las 1,100 cuentas; migración de cuentas ejecutivas a autenticación FIDO2 (llave de seguridad física).

Simulacro de phishing BEC: Ejercicio ejecutado a los 7 días del incidente para los 1,100 empleados con escenario de suplantación del CISO. Tasa de clics inicial: 8.3% — línea base establecida.

Comunicación ejecutiva: Brief al CISO y CEO Dario Amodei a las 3 horas. Reporte al Board of Directors al día siguiente. Coordinación con el equipo de Threat Intelligence para incorporar IOCs al reporte público trimestral.

Ciclo PDCA — Fase CHECK

Verificar: Evaluar la efectividad de cada control implementado frente al riesgo Extremo (20) de BEC, medir el impacto residual y contrastar los KPIs con las metas definidas en PLAN.

③ CHECK — Verificación de efectividad y auditoría post-incidente

Efectividad del MFA: Alta — único control que bloqueó el compromiso real. La autenticación FIDO2 en cuentas ejecutivas eliminó el vector de phishing de credenciales para ese segmento.

Efectividad del DMARC: Alta para correos futuros: intentos de suplantación del dominio @anthropic.com cayeron a cero en los 30 días post-activación. El filtro anti-BEC bloqueó 4 intentos adicionales en ese período.

Efectividad del simulacro: Progresiva: tasa de clics inicial 8.3% (91 empleados). Tras la formación post-incidente, el simulacro del mes siguiente registró 2.1%. Meta de < 2% alcanzada en el tercer simulacro.

Efectividad del banner externo: Media-Alta: encuesta post-incidente reveló que el 74% de los empleados habría identificado el correo malicioso como externo si el banner hubiera estado activo en el momento del ataque.

Brecha residual #1: El correo malicioso llegó desde un dominio secundario no cubierto por las reglas DMARC iniciales. Se identificaron 2 dominios adicionales de Anthropic sin configuración DMARC activa.

Brecha residual #2: El procedimiento de reporte de phishing no estaba integrado en el cliente de correo. El empleado tardó 23 minutos adicionales en localizar el canal de reporte, elevando el MTTD total a 47 minutos.

KPI #1 — MTTD: Tiempo de detección: 47 minutos. Meta establecida post-incidente: < 10 minutos mediante integración de telemetría de correo con SIEM en tiempo real y botón de reporte directo.

KPI #2 — Cobertura MFA: Pre-incidente: 98.7% de cuentas con MFA. Post-incidente: 100% verificado, con cuentas ejecutivas migradas a FIDO2. Meta: mantener 100% con revisión mensual automatizada.

Auditoría ISO 9.2: Revisión interna completada: la política de correo no contemplaba el vector BEC asistido por IA ni el filtrado anti-spoofing de display names ejecutivos. Requiere actualización formal.

Ciclo PDCA — Fase ACT

Actuar: Estandarizar los controles efectivos, cerrar las brechas residuales y actualizar la política de correo corporativo para reducir el riesgo de Extremo (20) a un nivel aceptable.

④ ACT — Mejora continua y actualización del SGSI

Mejora #1 — Política actualizada: La Política de Uso Seguro del Sistema de Correo Electrónico Corporativo incorpora: sección BEC con controles DMARC/anti-spoofing, autenticación FIDO2 para ejecutivos y simulacros trimestrales obligatorios.

Mejora #2 — DMARC completo: Cobertura DMARC policy=reject extendida a todos los dominios y subdominios de Anthropic; revisión mensual automatizada con alerta al equipo de seguridad ante configuraciones incompletas o degradadas.

Mejora #3 — Reporte integrado: Botón de reporte de phishing integrado en Google Workspace; al activarlo, genera ticket automático en el sistema de gestión de incidentes con captura del correo y cabeceras, reduciendo MTDD a < 10 minutos.

Mejora #4 — SIEM + correo en tiempo real: Integración de telemetría de Google Workspace con el SIEM; reglas de correlación para detectar patrones BEC: correo con display name ejecutivo + dominio externo + clic de empleado + IP anómala.

Mejora #5 — Formación continua: Simulacros trimestrales de phishing BEC con escenarios de IA generativa; formación diferenciada para Research, Safety y liderazgo ejecutivo; meta de tasa de clics < 2% como indicador permanente del SGSI.

Lección aprendida #1: El MFA fue la única barrera que impidió el compromiso real. En un riesgo Extremo (20), depender de un solo control es insostenible: la defensa en profundidad debe activarse de forma preventiva, no reactiva.

Lección aprendida #2: Los ataques BEC asistidos por IA producen correos indistinguibles del 8.3% de los empleados. La política de correo debe actualizarse al mismo ritmo que evoluciona la amenaza, no solo tras los incidentes.

Próxima revisión: Auditoría de controles de correo y simulacro Q1 programado para el 15 de enero de 2025. Responsable: CISO + Equipo de Seguridad Corporativa + RRHH.

Estado del Riesgo tras el Ciclo PDCA

RIESGO INICIAL	PROB. RESIDUAL	IMPACTO RESIDUAL	RIESGO RESIDUAL
Extremo (20)	03 — Posible	04 — Mayor	ALTO (12)

Reducción obtenida: de Extremo (20) a Alto (12) mediante implementación de DMARC completo, MFA/FIDO2 al 100%, filtro anti-BEC y formación continua. El riesgo residual Alto (12) requiere seguimiento activo en el próximo ciclo PDCA con meta de reducción a Medio (8) al cierre del Q2 2025. Dado que es un riesgo que involucra al eslabón mas débil, se considera que la reducción a 12 ya es bastante buena.

Sección 9 - EVALUACIÓN DEL DESEMPEÑO

Checklist de supervisión de las 20 políticas del SGSI

ANTHROPIC

EVALUACION DEL DESEMPEÑO

Checklist de Cumplimiento basado en las Políticas de la Cláusula 5
ISO 27001:2022 | 20 Activos con sus Políticas Cubiertos

Fecha de Evaluacion	Responsable	Periodo Auditado
____/____/____	_____	_____

Instrucciones: Para cada requerimiento marque [Si] si se cumple o [No] si no se cumple. Registre evidencias u observaciones en la ultima columna.

01

Amazon Web Services (AWS)
Política de Gestion de Accesos e Identidades en Infraestructura Cloud

Tipo	Requerimiento de la Politica	Cumple	Observaciones / Evidencia
ESTANDAR	MFA implementado para todas las cuentas IAM con acceso a Amazon Bedrock y clusters Trainium.	☐ Si ☐ No	
DIRECTRIZ	Permisos IAM auditados trimestralmente para identificar cuentas con privilegios excesivos o inactivas.	☐ Si ☐ No	
DIRECTRIZ	Cuentas con privilegios excesivos o inactivas identificadas y corregidas.	☐ Si ☐ No	
PROCEDIMIENTO	Todo acceso nuevo solicitado por el lider de equipo y aprobado por el CISO.	☐ Si ☐ No	
PROCEDIMIENTO	Accesos nuevos documentados en el sistema de tickets.	☐ Si ☐ No	
LINEA BASE	Credenciales rotadas cada 90 dias.	☐ Si ☐ No	
LINEA BASE	Contraseñas de minimo 16 caracteres en todas las cuentas IAM.	☐ Si ☐ No	

02

Google Cloud Platform (GCP)*Política de Control de Accesos y Roles en Plataformas Cloud*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	MFA obligatorio habilitado para todos los usuarios con acceso a Vertex AI y servicios GCP.	☐ Si ☐ No	
DIRECTRIZ	Roles y permisos en GCP IAM revisados mensualmente.	☐ Si ☐ No	
DIRECTRIZ	Accesos no utilizados en los últimos 30 días eliminados.	☐ Si ☐ No	
PROCEDIMIENTO	Accesos solicitados mediante formulario formal con aprobación del responsable técnico.	☐ Si ☐ No	
PROCEDIMIENTO	Solicitudes y aprobaciones registradas en bitácora.	☐ Si ☐ No	
LINEA BASE	Cuentas de servicio renuevan claves cada 90 días.	☐ Si ☐ No	
LINEA BASE	Principio de mínimo privilegio aplicado en todas las cuentas de servicio.	☐ Si ☐ No	

03

Microsoft Azure AD*Política de Autenticación y Gestión de Identidades Corporativas*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	Azure Active Directory MFA habilitado para todos los usuarios con acceso a recursos de cómputo e inferencia.	☐ Si ☐ No	
DIRECTRIZ	Auditorías bimestrales de roles y grupos en Azure AD realizadas.	☐ Si ☐ No	
DIRECTRIZ	Permisos huérfanos detectados y eliminados en cada auditoría.	☐ Si ☐ No	
PROCEDIMIENTO	Nuevos accesos requieren solicitud formal y validación del área de seguridad.	☐ Si ☐ No	
PROCEDIMIENTO	Activación de nuevos accesos realizada de forma supervisada.	☐ Si ☐ No	
LINEA BASE	Contraseñas cambiadas cada 90 días.	☐ Si ☐ No	
LINEA BASE	Cuentas sin actividad por 30 días suspendidas automáticamente.	☐ Si ☐ No	

04

Proyecto Rainier (Trainium2)*Política de Acceso Restringido a Infraestructura de Entrenamiento de Modelos*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	Acceso al cluster Trainium2 restringido exclusivamente al equipo de entrenamiento de modelos.	☐ Si ☐ No	
ESTANDAR	MFA obligatorio habilitado para todos los usuarios del cluster.	☐ Si ☐ No	
DIRECTRIZ	Registros de acceso al cluster auditados semanalmente para detectar accesos anómalos o no autorizados.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso aprobado por el Director de Infraestructura antes de ser asignado.	☐ Si ☐ No	
PROCEDIMIENTO	Vigencia de cada acceso revisada cada 30 días.	☐ Si ☐ No	
LINEA BASE	Credenciales de acceso al cluster rotadas cada 90 días.	☐ Si ☐ No	
LINEA BASE	Credenciales nunca compartidas entre usuarios del cluster.	☐ Si ☐ No	

05

Puerta de Enlace IA Cloudflare*Política de Administración Segura de Gateways de Inteligencia Artificial*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	MFA habilitado para todos los usuarios con acceso al panel de administración de Cloudflare AI Gateway.	☐ Si ☐ No	
DIRECTRIZ	Reglas de enrutamiento y permisos de administración revisados mensualmente.	☐ Si ☐ No	
PROCEDIMIENTO	Cambios de configuración y nuevos accesos aprobados por el equipo de operaciones.	☐ Si ☐ No	
PROCEDIMIENTO	Cambios registrados con marca de tiempo.	☐ Si ☐ No	
LINEA BASE	Claves API rotadas cada 90 días.	☐ Si ☐ No	
LINEA BASE	Claves API almacenadas únicamente en el gestor de secretos autorizado.	☐ Si ☐ No	

06

API Publica de Claude*Política de Gestion del Ciclo de Vida de Claves API*

Tipo	Requerimiento de la Politica	Cumple	Observaciones / Evidencia
ESTANDAR	Todas las claves API generadas con permisos minimos.	☐ Si ☐ No	
ESTANDAR	Cada clave API asociada a un usuario o sistema identificado.	☐ Si ☐ No	
DIRECTRIZ	Claves API activas auditadas trimestralmente.	☐ Si ☐ No	
DIRECTRIZ	Claves sin actividad en 60 dias revocadas.	☐ Si ☐ No	
PROCEDIMIENTO	Nuevas claves generadas desde el portal oficial con registro del proposito y responsable.	☐ Si ☐ No	
LINEA BASE	Claves rotadas cada 90 dias.	☐ Si ☐ No	
LINEA BASE	Claves comprometidas revocadas en maximo 2 horas tras su deteccion.	☐ Si ☐ No	

07

Snowflake*Política de Acceso y Privilegios en Plataformas de Datos*

Tipo	Requerimiento de la Politica	Cumple	Observaciones / Evidencia
ESTANDAR	MFA habilitado para todos los usuarios con acceso a la integracion de Snowflake en el Claude Marketplace.	☐ Si ☐ No	
DIRECTRIZ	Roles de Snowflake por usuario revisados bimestralmente.	☐ Si ☐ No	
DIRECTRIZ	Principio de minimo privilegio verificado en cada revision bimestral.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso solicitado con justificacion de negocio y aprobado por el responsable de datos.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso activado con perfil restringido.	☐ Si ☐ No	
LINEA BASE	Contraseñas cambiadas cada 90 dias.	☐ Si ☐ No	
LINEA BASE	Cuentas de servicio usan autenticacion por certificado.	☐ Si ☐ No	

08

Broadcom - Infraestructura de Red*Política de Administración Segura de Infraestructura de Red*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	MFA habilitado para todos los administradores con acceso a la infraestructura de red Broadcom.	☐ Si ☐ No	
ESTANDAR	Acceso basado en roles implementado en la infraestructura de red.	☐ Si ☐ No	
DIRECTRIZ	Accesos administrativos a equipos de red auditados mensualmente.	☐ Si ☐ No	
DIRECTRIZ	Logs de cambios de configuración revisados en cada auditoría mensual.	☐ Si ☐ No	
PROCEDIMIENTO	Solicitudes de acceso aprobadas por el equipo de redes.	☐ Si ☐ No	
PROCEDIMIENTO	Solicitudes documentadas en el sistema de cambios.	☐ Si ☐ No	
LINEA BASE	Credenciales de administración rotadas cada 90 días.	☐ Si ☐ No	
LINEA BASE	Credenciales no reutilizadas entre dispositivos de red.	☐ Si ☐ No	

09

DNS y CDN Externo*Política de Control y Monitoreo de Servicios de Resolución y Distribución*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	MFA habilitado para todos los accesos al panel de administración de DNS y CDN (Claude.ai y API).	☐ Si ☐ No	
DIRECTRIZ	Registros DNS y reglas CDN revisados mensualmente.	☐ Si ☐ No	
DIRECTRIZ	Configuraciones no autorizadas o modificaciones inesperadas detectadas y reportadas.	☐ Si ☐ No	
PROCEDIMIENTO	Cambios en DNS/CDN solicitados formalmente y aprobados por infraestructura.	☐ Si ☐ No	
PROCEDIMIENTO	Cambios ejecutados dentro de ventana de cambio programado.	☐ Si ☐ No	
LINEA BASE	Credenciales rotadas cada 90 días.	☐ Si ☐ No	
LINEA BASE	Alertas habilitadas ante cualquier modificación de registros críticos.	☐ Si ☐ No	

10

Inteligencia de Amenazas Externas*Política de Acceso a Fuentes de Inteligencia de Ciberseguridad*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	Acceso a feeds de inteligencia de amenazas e IOCs restringido al equipo de seguridad.	☐ Si ☐ No	
ESTANDAR	MFA obligatorio habilitado para todos los usuarios de plataformas de inteligencia.	☐ Si ☐ No	
DIRECTRIZ	Usuarios con acceso a plataformas de inteligencia auditados trimestralmente.	☐ Si ☐ No	
DIRECTRIZ	Accesos de personal fuera del equipo de seguridad eliminados.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso solicitado con justificación de rol y aprobado por el CISO.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso revisado semestralmente para confirmar vigencia.	☐ Si ☐ No	
LINEA BASE	Credenciales rotadas cada 90 días.	☐ Si ☐ No	
LINEA BASE	Credenciales nunca compartidas entre analistas.	☐ Si ☐ No	

11

Laptops y Workstations del Personal*Política de Seguridad de Dispositivos de Usuario Final*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	MFA habilitado para el inicio de sesión en todos los dispositivos (biometría o token físico).	☐ Si ☐ No	
DIRECTRIZ	Inventario de dispositivos activos auditado semestralmente.	☐ Si ☐ No	
DIRECTRIZ	Verificado que solo empleados vigentes tienen acceso activo a dispositivos.	☐ Si ☐ No	
PROCEDIMIENTO	Al incorporar empleado: dispositivo asignado con perfil mínimo.	☐ Si ☐ No	
PROCEDIMIENTO	Al dar de baja empleado: dispositivo formateado y dado de baja en máximo 24 horas.	☐ Si ☐ No	
LINEA BASE	Contraseña local cambiada cada 90 días.	☐ Si ☐ No	
LINEA BASE	Bloqueo automático habilitado tras 5 minutos de inactividad.	☐ Si ☐ No	

12

Servidores Internos de Desarrollo*Política de Acceso Controlado a Entornos de Desarrollo y Staging*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	MFA habilitado para todos los accesos a servidores de desarrollo y staging de modelos.	☐ Si ☐ No	
DIRECTRIZ	Usuarios con acceso SSH/RDP revisados mensualmente.	☐ Si ☐ No	
DIRECTRIZ	Accesos de proyectos finalizados revocados en cada revision mensual.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso solicitado mediante ticket y aprobado por el lider tecnico.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso asignado con fecha de vencimiento definida.	☐ Si ☐ No	
LINEA BASE	Credenciales rotadas cada 90 dias.	☐ Si ☐ No	
LINEA BASE	Acceso root solo bajo sesion supervisada y registrada.	☐ Si ☐ No	

13

Red LAN Corporativa*Política de Seguridad y Control de Acceso a la Red Interna*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	Acceso a la LAN requiere autenticacion por certificado de dispositivo mas credenciales de usuario con MFA.	☐ Si ☐ No	
DIRECTRIZ	Dispositivos conectados a la LAN auditados trimestralmente.	☐ Si ☐ No	
DIRECTRIZ	Equipos no autorizados o con comportamiento anomalo identificados y reportados.	☐ Si ☐ No	
PROCEDIMIENTO	Todo nuevo dispositivo registrado y aprobado por TI antes de conectarse a la red.	☐ Si ☐ No	
LINEA BASE	Credenciales de red renovadas cada 90 dias.	☐ Si ☐ No	
LINEA BASE	Dispositivos inactivos por 15 dias retirados automaticamente de la red.	☐ Si ☐ No	

14

VPN Corporativa

Política de Acceso Remoto Seguro mediante VPN

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	Acceso VPN requiere MFA obligatorio combinando contraseña con OTP.	☐ Si ☐ No	
DIRECTRIZ	Registros de conexión VPN revisados mensualmente.	☐ Si ☐ No	
DIRECTRIZ	Accesos desde ubicaciones inusuales o fuera de horario detectados y reportados.	☐ Si ☐ No	
PROCEDIMIENTO	Solicitud de acceso tramitada por TI con aprobación del responsable del empleado.	☐ Si ☐ No	
PROCEDIMIENTO	Perfil de acceso mínimo configurado al activar VPN.	☐ Si ☐ No	
LINEA BASE	Contraseñas VPN cambiadas cada 90 días.	☐ Si ☐ No	
LINEA BASE	Sesiones inactivas por 30 minutos cerradas automáticamente.	☐ Si ☐ No	

15

Repositorios Internos de Código

Política de Gestión de Accesos a Repositorios de Código Fuente

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	MFA habilitado para todos los usuarios con acceso a repositorios privados de código de Claude.	☐ Si ☐ No	
DIRECTRIZ	Permisos de lectura/escritura auditados mensualmente.	☐ Si ☐ No	
DIRECTRIZ	Solo personal activo del proyecto tiene acceso en cada revisión mensual.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso solicitado con proyecto y nivel de permiso requerido, aprobado por líder técnico.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso registrado en el sistema de gestión de accesos.	☐ Si ☐ No	
LINEA BASE	Tokens de acceso personal rotados cada 90 días.	☐ Si ☐ No	
LINEA BASE	Acceso de ex-empleados revocado dentro de las primeras 2 horas tras la baja.	☐ Si ☐ No	

16

Documentacion Tecnica Interna*Política de Protección y Acceso a Documentación Clasificada*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	Acceso a documentacion de arquitectura y diseno de modelos restringido a personal con necesidad justificada.	☐ Si ☐ No	
ESTANDAR	MFA obligatorio habilitado para acceder a documentacion tecnica interna.	☐ Si ☐ No	
DIRECTRIZ	Permisos de acceso a documentacion sensible revisados semestralmente.	☐ Si ☐ No	
DIRECTRIZ	Accesos de empleados que cambiaron de area eliminados en cada revision.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso solicitado con justificacion de proyecto y aprobado por responsable del area.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso registrado en el sistema de control de accesos.	☐ Si ☐ No	
LINEA BASE	Credenciales renovadas cada 90 dias.	☐ Si ☐ No	
LINEA BASE	Documentos descargados registrados en el registro de auditoria.	☐ Si ☐ No	

17

Sistema de Correo Corporativo*Política de Uso Seguro del Sistema de Correo Electrónico Corporativo*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	MFA implementado para todos los usuarios del sistema de correo corporativo sin excepcion de rol.	☐ Si ☐ No	
DIRECTRIZ	Cuentas de correo activas auditadas trimestralmente.	☐ Si ☐ No	
DIRECTRIZ	Cuentas de empleados que ya no pertenecen a la organizacion desactivadas.	☐ Si ☐ No	
PROCEDIMIENTO	Nuevas cuentas solicitadas por RRHH al incorporar empleado.	☐ Si ☐ No	
PROCEDIMIENTO	Baja de cuenta ejecutada el mismo dia de la salida del empleado.	☐ Si ☐ No	
LINEA BASE	Contraseñas cambiadas cada 90 dias.	☐ Si ☐ No	
LINEA BASE	Reenvio automatico a cuentas externas deshabilitado por defecto.	☐ Si ☐ No	

18

Plataforma de Mensajería Interna*Política de Seguridad en Plataformas de Comunicación Interna*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	MFA habilitado para todos los usuarios incluyendo bots e integraciones automatizadas.	☐ Si ☐ No	
DIRECTRIZ	Canales privados y permisos revisados mensualmente.	☐ Si ☐ No	
DIRECTRIZ	Verificado que no existen usuarios externos con acceso a canales sensibles.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso otorgado automáticamente al incorporar empleado con perfil estandar.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso revocado dentro de las primeras 4 horas tras la baja del empleado.	☐ Si ☐ No	
LINEA BASE	Contraseñas rotadas cada 90 días.	☐ Si ☐ No	
LINEA BASE	Sesiones en dispositivos no reconocidos cerradas y notificadas al usuario.	☐ Si ☐ No	

19

Bases de Datos de Investigación*Política de Acceso y Protección de Datos de Investigación*

Tipo	Requerimiento de la Política	Cumple	Observaciones / Evidencia
ESTANDAR	Acceso a bases de datos de investigación restringido exclusivamente al equipo investigador.	☐ Si ☐ No	
ESTANDAR	MFA y acceso por roles definidos habilitados en todas las bases de datos.	☐ Si ☐ No	
DIRECTRIZ	Accesos auditados mensualmente revisando consultas inusuales en volumen u horario.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso solicitado con descripción del proyecto y aprobado por líder de investigación.	☐ Si ☐ No	
PROCEDIMIENTO	Acceso asignado con fecha de vencimiento acorde al proyecto.	☐ Si ☐ No	
LINEA BASE	Credenciales rotadas cada 90 días.	☐ Si ☐ No	
LINEA BASE	Acceso directo a producción prohibido; solo permitido vía entorno controlado.	☐ Si ☐ No	

20

Sistema de Respaldo y Recuperacion*Política de Gestion Segura de Copias de Seguridad y Recuperacion*

Tipo	Requerimiento de la Politica	Cumple	Observaciones / Evidencia
ESTANDAR	MFA habilitado para todos los administradores con acceso al sistema de copias de seguridad y recuperacion ante desastres.	☐ Si ☐ No	
DIRECTRIZ	Permisos del sistema de respaldo auditados trimestralmente.	☐ Si ☐ No	
DIRECTRIZ	Verificado que solo infraestructura tiene permisos de escritura y restauracion.	☐ Si ☐ No	
PROCEDIMIENTO	Restauracion solicitada formalmente y aprobada por el CISO.	☐ Si ☐ No	
PROCEDIMIENTO	Restauracion ejecutada bajo supervision de al menos dos administradores.	☐ Si ☐ No	
LINEA BASE	Credenciales de administracion rotadas cada 90 dias.	☐ Si ☐ No	
LINEA BASE	Intentos de acceso fallidos generan alerta inmediata al equipo de seguridad.	☐ Si ☐ No	

FIRMAS Y APROBACION**Auditor Interno / Evaluador****CISO / Responsable de Seguridad**

Nombre y Firma

Nombre y Firma

Fecha

Fecha

Sección 10 - MEJORA

No conformidad, acción correctiva y caso real de mejora

ANTHROPIC

No Conformidad y Acción Correctiva

Incidente de referencia: Phishing / Business Email Compromise (BEC) — Política de Uso Seguro del Sistema de Correo Electrónico Corporativo
Registro: NC-2024-017 · Clasificación: No Conformidad Mayor · Riesgo origen: Extremo (20)

01 — ¿Qué ocurrió?

El 14 de octubre de 2024, un empleado del equipo de Safety de Anthropic recibió un correo electrónico que suplantaba la identidad del CISO corporativo, generado mediante técnicas de ingeniería social asistida por inteligencia artificial. El mensaje solicitaba validación urgente de credenciales a través de un portal externo controlado por el atacante, siguiendo el patrón de Business Email Compromise (BEC) documentado por el grupo norcoreano GTG-DPRK-0421 en el Informe de Amenazas de Anthropic de agosto 2025.

El empleado accedió al enlace malicioso. El intento de autenticación fue bloqueado por el MFA activo en la cuenta, evitando el compromiso real de credenciales. Sin embargo, el incidente expuso brechas significativas en los controles preventivos de la Política de Uso Seguro del Sistema de Correo Electrónico Corporativo, lo que constituye una No Conformidad Mayor respecto a los requisitos de la Cláusula 8.1 de ISO 27001:2022.

Identificación de la No Conformidad

Referencia	NC-2024-017
Cláusula ISO afectada	8.1 — Planificación y control operacional · 6.1.2 — Evaluación de riesgos
Política incumplida	Política de Uso Seguro del Sistema de Correo Electrónico Corporativo
Tipo	No Conformidad Mayor — el incidente se materializó por ausencia de controles preventivos definidos en la política
Detectada por	Empleado afectado (notificación manual) + alerta del SIEM a los 47 minutos
Fecha de registro	14 de octubre de 2024
Responsable del registro	CISO — Equipo de Seguridad Corporativa de Anthropic

02 — Consecuencias indeseables y medidas de contención

El incidente generó las siguientes consecuencias indeseables que requirieron contención inmediata:

CONSECUENCIAS IDENTIFICADAS
Exposición del vector BEC: El correo malicioso llegó a 3 empleados del equipo de Safety sin ser interceptado por los filtros de correo existentes, evidenciando ausencia de DMARC estricto en dominios secundarios.
Brecha en tiempo de respuesta: El empleado tardó 23 minutos en localizar el canal de reporte de incidentes al no estar integrado en el cliente de correo, elevando el tiempo de detección total a 47 minutos.
Gap de concienciación: El 8.3% de los empleados (91 de 1,100) hizo clic en el correo malicioso durante el simulacro ejecutado 7 días después del incidente, confirmando exposición al vector BEC en toda la organización.
Política desactualizada: La Política de Correo Corporativo vigente no contemplaba el vector de spear-phishing asistido por IA ni el filtrado anti-spoofing de display names ejecutivos, constituyendo una no conformidad documental.

Medidas de contención adoptadas inmediatamente para limitar el impacto:

MEDIDAS DE CONTENCIÓN
0–30 minutos: Bloqueo preventivo de la cuenta afectada, revocación de sesiones activas y forzado de re-autenticación MFA en dispositivo corporativo verificado.
0–1 hora: Aislamiento del dominio del portal falso en el filtro DNS corporativo; alerta interna a todos los empleados con descripción del correo malicioso.
0–2 horas: Análisis forense de cabeceras DKIM/SPF del correo malicioso; identificación de los 3 destinatarios; comunicación al CISO y CEO Dario Amodei.
24–72 horas: Activación de DMARC policy=reject en los 3 dominios corporativos; auditoría de MFA en el 100% de las 1,100 cuentas; corrección de 14 cuentas sin MFA configurado.

03 — Causa raíz del suceso

El análisis post-incidente identificó tres causas raíz interrelacionadas que permitieron la materialización del riesgo BEC:

ANÁLISIS DE CAUSA RAÍZ (MÉTODO 5 POR QUÉS)
Causa raíz #1 — Técnica: Ausencia de DMARC policy=reject en dominios secundarios de Anthropic, lo que permitió que correos con dominio falsificado llegaran a las bandejas de entrada sin ser marcados como sospechosos.
Causa raíz #2 — Proceso: La Política de Correo Corporativo no había sido actualizada para incluir el vector de BEC asistido por IA. Los simulacros de phishing no se habían ejecutado en los 6 meses previos al incidente.
Causa raíz #3 — Personas: Sin un botón de reporte integrado en el cliente de correo, el tiempo de notificación manual fue 23 minutos superior al objetivo, reduciendo la ventana de contención efectiva.
Factor agravante: El grupo GTG-DPRK-0421 usó Claude para generar lures altamente personalizados que replicaban el tono y estilo del CISO, haciendo el correo indistinguible para el 8.3% de los empleados.

04 — Medidas adoptadas para eliminar la causa raíz

ACCIONES CORRECTIVAS IMPLEMENTADAS
AC-01 — DMARC completo: Activación de DMARC policy=reject + SPF/DKIM estrictos en todos los dominios y subdominios de Anthropic. Revisión mensual automatizada con alerta al equipo de seguridad. Fecha: 17 octubre 2024.
AC-02 — Filtro anti-BEC: Regla de filtrado que detecta y bloquea correos donde el display name corresponde a un ejecutivo de Anthropic pero el dominio del remitente es externo o no verificado. Fecha: 17 octubre 2024.
AC-03 — MFA / FIDO2: Verificación al 100% de MFA en todas las cuentas; migración de cuentas ejecutivas y de alta sensibilidad a autenticación FIDO2 resistente a phishing. Fecha: 21 octubre 2024.
AC-04 — Botón de reporte: Botón de reporte de phishing integrado en Google Workspace; genera ticket automático con captura del correo y cabeceras en el sistema de gestión de incidentes. Fecha: 28 octubre 2024.
AC-05 — SIEM + telemetría correo: Integración de telemetría de Google Workspace con el SIEM; reglas de correlación BEC: display name ejecutivo + dominio externo + clic + IP anómala. Fecha: 4 noviembre 2024.
AC-06 — Simulacros trimestrales: Programa trimestral de simulacros de phishing BEC con escenarios de IA generativa; formación diferenciada para Research, Safety y liderazgo. Primer simulacro: 21 octubre 2024.
AC-07 — Política actualizada: Política de Uso Seguro del Sistema de Correo Electrónico Corporativo revisada: incorpora sección BEC, controles DMARC/anti-spoofing, FIDO2 y simulacros. Aprobada: 31 octubre 2024.

05 — Evaluación de la eficacia de las medidas adoptadas

INDICADORES DE EFICACIA — MEDICIÓN A 90 DÍAS	
KPI #1 — MTTD :	Tiempo medio de detección: redujo de 47 minutos a 8 minutos tras la integración SIEM + botón de reporte. Meta: < 10 minutos. ✓ Alcanzada.
KPI #2 — Cobertura MFA :	100% de cuentas con MFA verificado; 100% de cuentas ejecutivas migradas a FIDO2. Meta: 100%. ✓ Alcanzada y mantenida.
KPI #3 — Tasa de clics phishing :	Simulacro Q4 2024: 8.3% → Simulacro Q1 2025: 2.1% → Simulacro Q2 2025: 1.4%. Meta: < 2%. ✓ Alcanzada en el segundo simulacro.
KPI #4 — Suplantación de dominio :	Intentos de spoofing del dominio @anthropic.com detectados post-DMARC: 0. Intentos bloqueados por filtro anti-BEC en 30 días: 4. ✓ Control efectivo.
Riesgo inicial:	Extremo (20) — Probabilidad 5 × Impacto 4.
Riesgo residual post-corrección:	Alto (12) — Probabilidad 3 × Impacto 4. Reducción de 8 puntos. Seguimiento activo en próximo ciclo PDCA con meta de reducción a Medio (8).
Conclusión de eficacia:	Las acciones correctivas AC-01 a AC-07 eliminaron las tres causas raíz identificadas. El riesgo residual Alto (12) requiere seguimiento continuo pero no acción correctiva adicional inmediata.

Cierre del Registro de No Conformidad

Referencia	NC-2024-017
Estado	Cerrada — acciones correctivas implementadas y eficacia verificada
Fecha de cierre	15 de enero de 2025 — tras validación de KPIs en simulacro Q1 2025
Aprobado por	CISO + CEO Dario Amodei
Lección integrada al SGSI	La velocidad de evolución de las amenazas de IA exige que la política de correo se revise como mínimo semestralmente y que los simulacros se actualicen con nuevos vectores cada trimestre.

DE IGUAL MANERA EL SIGUIENTE BANNER SERÁ COMPARTIDO MEDIANTE CORREO Y JUNTAS DE MANERA CONSTANTE, PARA CONSCIENTIZAR A LOS PRESENTES Y FUTUROS TRABAJADORES DE LA EMPRESA ANTHROPIC DE NO CAER ANTE PHISHING Y DERIVADOS.

POLÍTICA 17 · USO SEGURO DEL CORREO CORPORATIVO

Tus credenciales son la llave del modelo



Reforzando estándares de seguridad para proteger nuestra infraestructura institucional ante amenazas de acceso no autorizado.



▲ RIESGO EXTREMO IDENTIFICADO

El análisis operacional determinó que el compromiso de cuentas mediante **phishing** o credenciales débiles representa una amenaza crítica. Un descuido en el correo corporativo puede ser la puerta de entrada para **exfiltraciones masivas** o manipulación de datos de investigación.

CUMPLIMIENTO OBLIGATORIO E INMEDIATO

Reglas de Seguridad

01

AUTENTICACIÓN DE MÚLTIPLES FACTORES (MFA) — MANDATORIA

Sin excepciones de rol o jerarquía. Toda cuenta activa de correo electrónico debe mantener habilitado y configurado el segundo factor de autenticación para mitigar cualquier intento de suplantación de identidad.



02

COMPLEJIDAD ESTRICTA DE CONTRASEÑAS

Toda credencial debe contar con una longitud mínima de **12 caracteres**, incorporando obligatoriamente mayúsculas, minúsculas, números y caracteres especiales. Cambia tu clave oportunamente.



03

PROHIBICIÓN DE REENVÍO AUTOMÁTICO EXTERNO

Por directiva del SGSI, el reenvío automático de correos institucionales hacia cuentas o dominios externos está **deshabilitado por defecto**. No expongas propiedad intelectual fuera de los entornos controlados.



¡La Seguridad es
un
Ciclo de Mejora
Continua!

EQUIPO 5

181700 · Castillo Gómez Edwin Admael

182033 · Castillo Olivera Carlos René

182217 · Hernández Fernández Diego Osvaldo

174702 · Tristán Rivera Magdalena Yesenia

PROTEGE · DETECTA ·
RESPONDE